



THAILAND NATIONAL CYBER ACADEMY

เสริมสร้างองค์ความรู้ สร้างทักษะ เพิ่มขีดความสามารถ
ด้านความมั่นคงความปลอดภัยทางไซเบอร์



Thailand National Cyber Academy

การทดสอบเจาะระบบพื้นฐาน (Basic Penetration Testing) – Day 2

โครงการพัฒนาบุคลากรด้านการตรวจสอบความมั่นคงปลอดภัยไซเบอร์และทดสอบเจาะระบบระดับสูง
(Offensive Security Certified Professional: OSCP Bootcamp)



ลงทะเบียนอบรม



วันที่ 4 พฤศจิกายน 2568 รอบเช้า



วิทยากร



Ammarit Thongthua
Cyber Security Specialist
Secure D Center , Thailand

Professional Certifications

Certified Information Systems Security Professional (CISSP)
Certified Secure Software Lifecycle Professional (CSSLP)
ISO27001 Lead Auditor
CISM, GXPN, OSCP, CCNP, CEH, Security+, CCNA

Education

Master of Cyber Security and Information Assurance, ICT
Mahidol University

Experience

16 years experience in

- Cyber Security Consultant
- Penetration Testing and Vulnerability Assessment
- Security Investigation and Defense



Certified
Secure
Software Lifecycle
Professional



Certified
Information
Systems Security
Professional



Certified Information
Security Manager®
An ISACA® Certification





วิทยากร



Research and Advisory



Ammarit Thongthua
Cyber Security Specialist
Secure D Center , Thailand

CVE-2024-21206: Oracle
CVE-2023-22037: Oracle
CVE-2023-0101 : Tenable
CVE-2022-38395: HP
CVE-2022-38699: ASUS
CVE-2021-36286 : DELL
CVE-2021-0100 : Intel
CVE-2020-6930 : HP
CVE-2020-14778: Oracle PeopleSoft
CVE-2020-14558: Oracle PeopleSoft
CVE-2020-14564: Oracle PeopleSoft
CVE-2020-9672: Adobe ColdFusion
CVE-2020-9673: Adobe ColdFusion

CVE-2020-5962: NVIDIA GPU Display Driver
CVE-2020-5342: Dell
CVE-2020-3961: VMware Horizon Client
CVE-2020-3768: Adobe ColdFusion
CVE-2020-4395: IBM Security Access Manager
CVE-2019-4725: IBM Security Access Manager
CVE-2019-8256: Adobe ColdFusion
CVE-2019-9490, Trend Micro
CVE-2019-7000, AVAYA Web Conference
CVE-2018-1067, Redhat JBoss Undertow
CVE-2016-5331, vCenter Server and ESXi



ตารางการอบรม



ตารางการทดสอบเจาะระบบพื้นฐาน

วันที่ 4 พฤศจิกายน 2568

เวลา	รายละเอียด
08:30–09:00	ลงทะเบียน (Registration)
09:00–10:30	Passive Reconnaissance (OSINT: Google dorking, WHOIS, DNS, social footprint)
10:30–10:45	พักเบรก – เข้า
10:45–12:00	Active Reconnaissance (port scanning, banner grabbing, service enumeration)
12:00–13:00	พักรับประทานอาหารกลางวัน
13:00–14:30	การทำแผนที่เครือข่ายและการระบุ fingerprint ของบริการ (Network mapping, service fingerprinting)
14:30–14:45	พักเบรก – บ่าย
14:45–16:00	การสำรวจออกแบบรายงานสรุป Recon



เอกสารประกอบการอบรม และ เครื่องมือต่างๆ



THNCA Thailand National Cyber Academy

NCSA สทศ

THAILAND NATIONAL CYBER ACADEMY

เสริมสร้างองค์ความรู้ สร้างทักษะ เพิ่มขีดความสามารถ
ด้านความมั่นคงความปลอดภัยทางไซเบอร์

YouTube Twitter LINE
Thailand National Cyber Academy

อบรมการทดสอบเจาะระบบพื้นฐาน (Basic Penetration Testing)

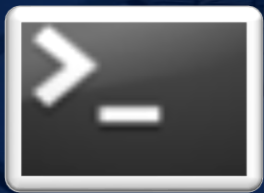
โครงการพัฒนาบุคลากรด้านการตรวจสอบความมั่นคงปลอดภัยไซเบอร์และทดสอบเจาะระบบระดับสูง
(Offensive Security Certified Professional: OSCP Bootcamp)

The most advanced Penetration Testing Distribution

Kali Linux is an open-source, Debian-based Linux distribution geared towards various information security tasks, such as Penetration Testing, Security Research, Computer Forensics and Reverse Engineering.

DOWNLOAD • DOCUMENTATION •

<https://bit.ly/NCSAPT25>



การสอดแนมแบบ : Reconnaissance



การสอดแนมแบบ : Reconnaissance





การสอดแนมแบบ : Reconnaissance





การสอดแนมแบบ : Reconnaissance

**Always cross check
the results with
multiple tools**





การสอดแนมแบบ : Reconnaissance

**Always cross check
the results with
multiple tools**

Tool A

Tool B

Tool C



การสอดแนมแบบ : Reconnaissance





การสอดแนมแบบ : Reconnaissance

Attack Surface





การสอดแนมแบบ : Reconnaissance

Attack Surface





การสอดแนมแบบ : Reconnaissance

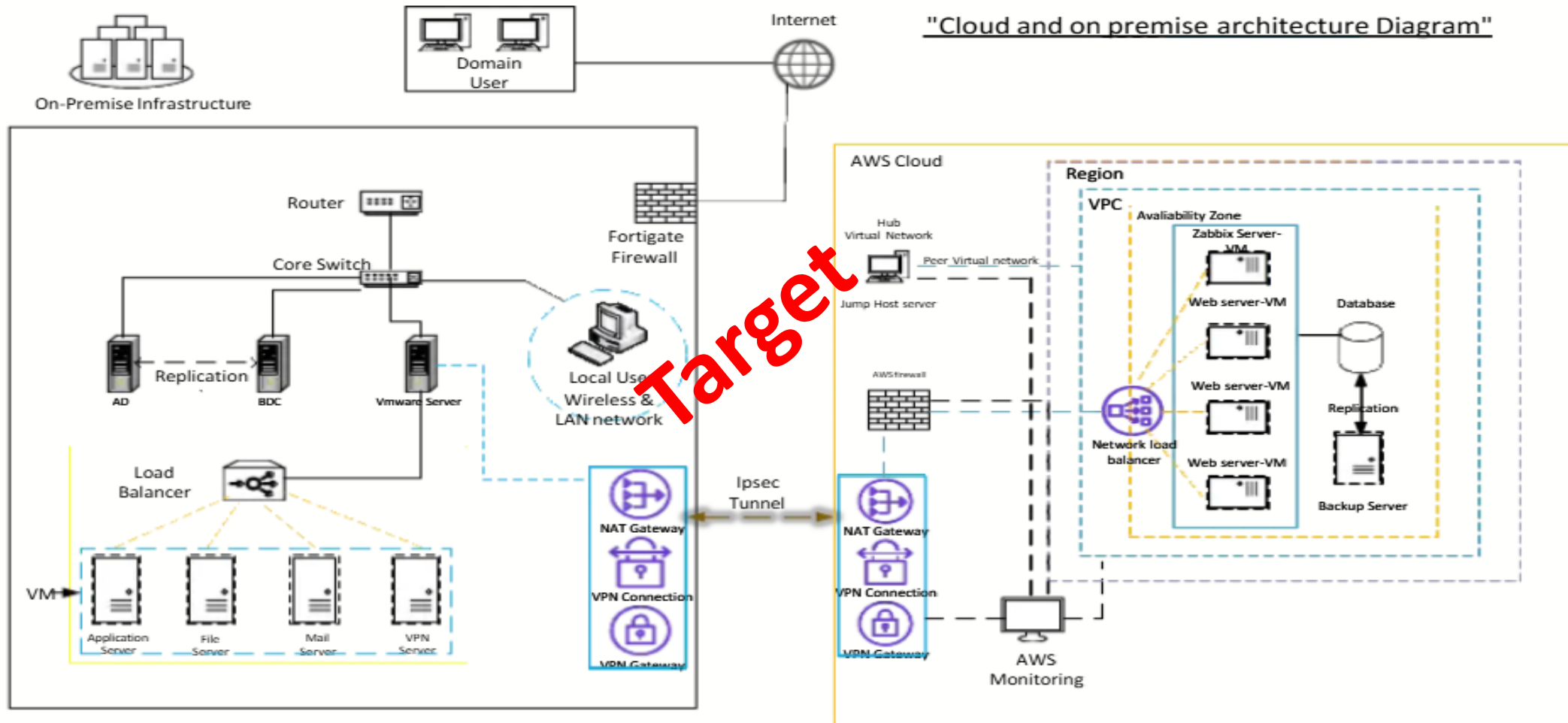
Attack Surface





การสอดแนมแบบ : Reconnaissance

❑ Attack Surface



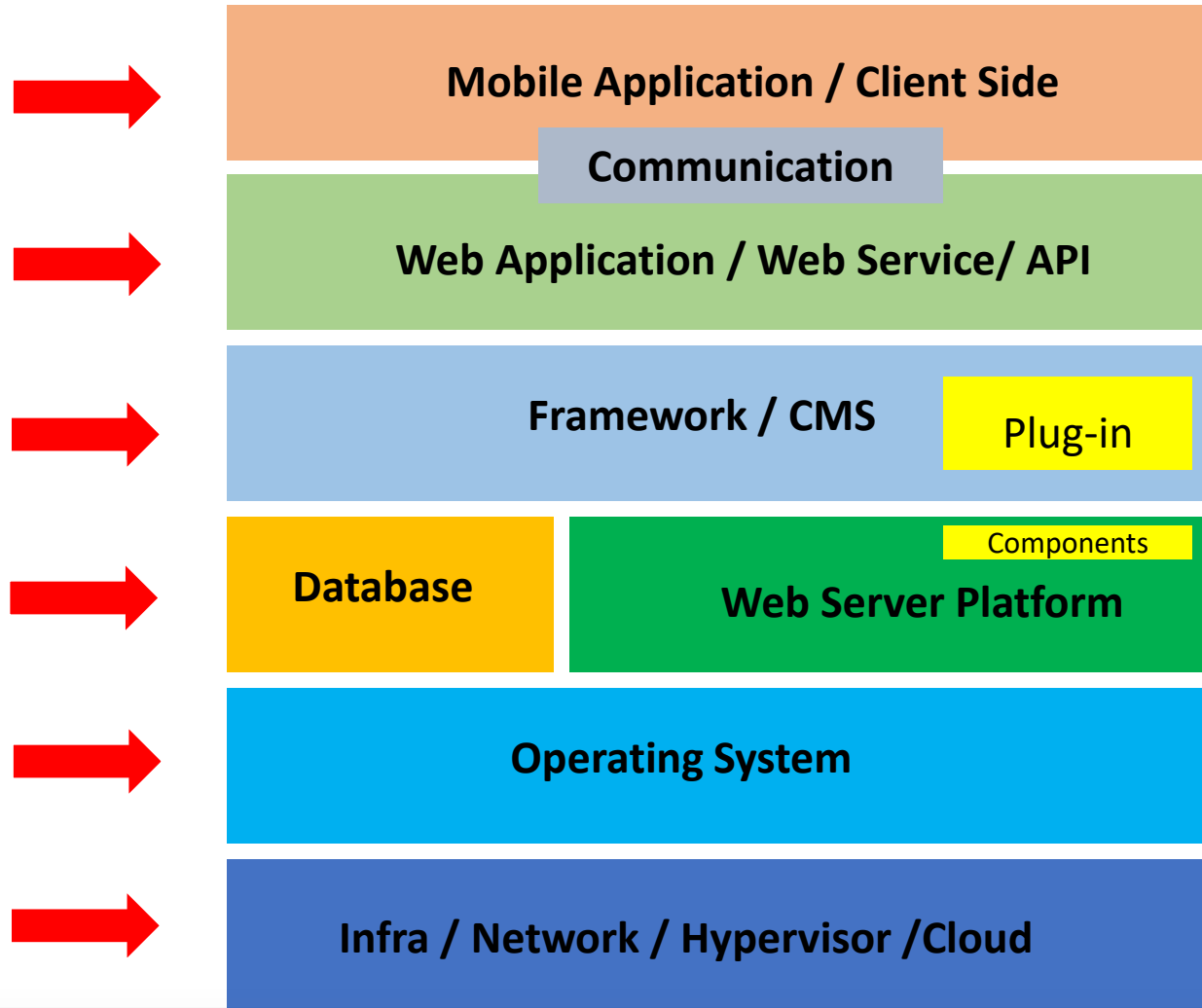


การสอดแนมแบบ : Reconnaissance

❑ Attack Surface



Threat Actor





การสอดแนมแบบ : Reconnaissance

Attack Surface



Threat Actor



Mobile Application / Client Side

Communication



Web Application / Web Service/ API



Framework / CMS

Plug-in



Database

Components

Web Server Platform



Operating System



Infra / Network / Hypervisor /Cloud

Public Code Repo

External Services

3rd Party / Vendor





การสอดแนมแบบ : Reconnaissance



Types of reconnaissance

- **Passive reconnaissance:** Gathers publicly available information without directly interacting with the target.
 - **Methods:** Researching public websites, social media, news articles, and public records.
- **Active reconnaissance:** Involves directly probing the target system to gain more specific information.
 - **Methods:** Port scanning, network mapping, and other direct interactions to identify open ports and live hosts. 

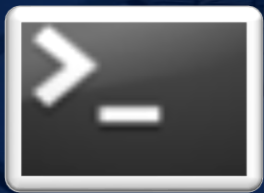


การสอดแนมแบบ : Reconnaissance



Information gathered during reconnaissance

- **Technical Information:**
 - IP addresses, domain names, and network topology
 - Open ports and services running on those ports
 - Operating systems, applications, and software versions
 - Leaked Data
- **Organizational and Human Information:**
 - Employee names and email addresses
 - Information about the company's structure, partners, and business partners
 - Details gathered from public sources like company websites and social media



Passive Reconnaissance



การสอดแนมแบบ : Reconnaissance

■ Kali

- *whois*

```
kali# whois vulnweb.com
```

- *dig*

```
kali# dig vulnweb.com
```

- *dnsrecon*

```
kali# dnsrecon vulnweb.com
```

- *dnsmap*

```
kali# dnsmap vulnweb.com -w wordlist.txt
```





การสอดแนมแบบ : Reconnaissance



■ Whois

who.is

[WHOIS](#) [RDAP](#) [DNS](#) [Uptime](#) [Domain Events](#) [Website](#)

WHOIS Domain Lookup

Look up registration details, contacts, and nameservers for any domain name

Search

vulnweb.com

WHOIS Information

IP Address: [44.228.249.3](#)

Whois

RDAP

DNS Records

Uptime

Diagnostics

Hide Data

Refresh Data

The domain vulnweb.com is registered. You can still try to buy it [here](#).

Contact Information

Registrant Contact

Name

Antevski Gjorgji

Organization

Acunetix Limited

Address

Mrieheil

MT

Phone

+356.79204709

Email

administrator [at] invicti [dot] com

Admin Contact

Name

Antevski Gjorgji

Organization

Acunetix Limited

Address

Mrieheil

MT

Phone

+356.79204709

Email

administrator [at] invicti [dot] com

Tech Contact

Name

Antevski Gjorgji

Organization

Acunetix Limited

Address

Mrieheil

MT

<https://who.is/rdap/vulnweb.com>





การสอดแนมแบบ : Reconnaissance

- Reverse IP Lookup

The screenshot shows the SINT.SH website's Reverse IP Lookup tool. The header includes the SINT.SH logo, navigation links (HOME, ALL TOOLS, ABOUT, API, TERMS OF SERVICE, CONTACT), and a SPONSOR button. The main heading is 'REVERSE IP LOOKUP' with a subtext: 'Perform a reverse IP lookup to find all A records associated with an IP address.' Below this is a text input field containing the placeholder 'IP, IPv6 or a domain' and a blue 'CHECK NOW' button.



การสอดแนมแบบ : Reconnaissance

- Get IP behind Cloudflare

```
root@localhost:~/Desktop/CloudFail# python cloudfail.py --target seo.com --tor

CloudFail
v1.0 by m0rtem

[16:37:54] Initializing CloudFail - the date/time is: 12/06/2016 16:37:54
[16:38:00] TOR connection established!
[16:38:00] New IP: 5.135.158.101
[16:38:00] Fetching initial information from: seo.com...
[16:38:00] Server IP: 104.28.2.64
[16:38:00] Testing if seo.com is on the Cloudflare network...
[16:38:00] seo.com is part of the Cloudflare network!
[16:38:00] Testing for misconfigured DNS using dnsdumpster...
[16:38:03] [FOUND:HOST] toolsapi.seo.com 107.170.121.228 AS62567 Digital Ocean, Inc. Un
[16:38:03] [FOUND:HOST] cm.seo.com Apache/2.4.7 (Ubuntu) 198.199.116.160 AS14061 Digital
[16:38:03] [FOUND:HOST] crm.seo.com nginx/1.4.6 (Ubuntu) 192.241.202.147 AS14061 Digital
[16:38:03] [FOUND:HOST] deathstar.seo.com Apache/2.4.6 (CentOS) PHP/5.4.16 104.236.144.1
[16:38:03] [FOUND:HOST] deathdev.seo.com 209.90.66.178 AS5048 FIBERNET Corp. United Sta
[16:38:03] [FOUND:HOST] host.seo.com nginx 173.255.232.177 AS8001 Net Access Corporation
[16:38:03] [FOUND:MX] 64.233.190.26 AS15169 Google Inc. 30 alt2.aspmx.l.google.com.
[16:38:03] [FOUND:MX] 74.125.141.26 AS15169 Google Inc. 20 alt1.aspmx.l.google.com.
[16:38:03] [FOUND:MX] 74.125.141.26 AS15169 Google Inc. 40 aspmx2.googlemail.com.
[16:38:03] [FOUND:MX] 64.233.176.26 AS15169 Google Inc. 10 aspmx.l.google.com.
[16:38:03] [FOUND:MX] 64.233.190.26 AS15169 Google Inc. 50 aspmx3.googlemail.com.
[16:38:03] Scanning crimeflare database...
[16:38:05] [FOUND:IP] 173.255.232.177
[16:38:05] [FOUND:IP] 198.74.56.156
[16:38:05] [FOUND:IP] 209.90.89.217
[16:38:05] Scanning 2898 subdomains, please wait...
[16:38:34] [FOUND:SUBDOMAIN] FOUND: blog.seo.com IP: 173.255.232.177 HTTP: 200
[16:38:38] [FOUND:SUBDOMAIN] FOUND: blogs.seo.com IP: 173.255.232.177 HTTP: 200
[16:39:04] [FOUND:SUBDOMAIN] FOUND: client.seo.com IP: 173.255.232.177 HTTP: 200
```



การสอดแนมแบบ : Reconnaissance

- Get IP behind Cloudflare

DNS History[HOME](#)[BROWSE](#)[RANDOM](#)[FAQ](#)[STATS](#)[REPORTS](#)[DISCORD](#)[CONTACT](#)

Domain Name System (DNS) Historical Record Archive.

With our new look website you can now find other domains hosted on the same IP address, your website neighbours and more even quicker than before.

Please be patient as the site returns from a long absence. If you have any problems please head over to our [discord](#) and let us know.

[prev](#)[next](#)

DNS Records

Domain: [dnshistory.org](#).
Added: 2009-07-20
Last updated: 2025-10-31

What points here by: [CNAME](#) / [NS](#) / [MX](#) / [PTR](#)
View: [SubDomains](#) / [Check DNS Propagation](#) / [Dig](#).

Domain Search



การสอดแนมแบบ : Reconnaissance

■ DNS Map

```
(kali@ kali)-[/usr/share/wordlists]
$ dnsmap
dnsmap 0.36 - DNS Network Mapper

usage: dnsmap <target-domain> [options]

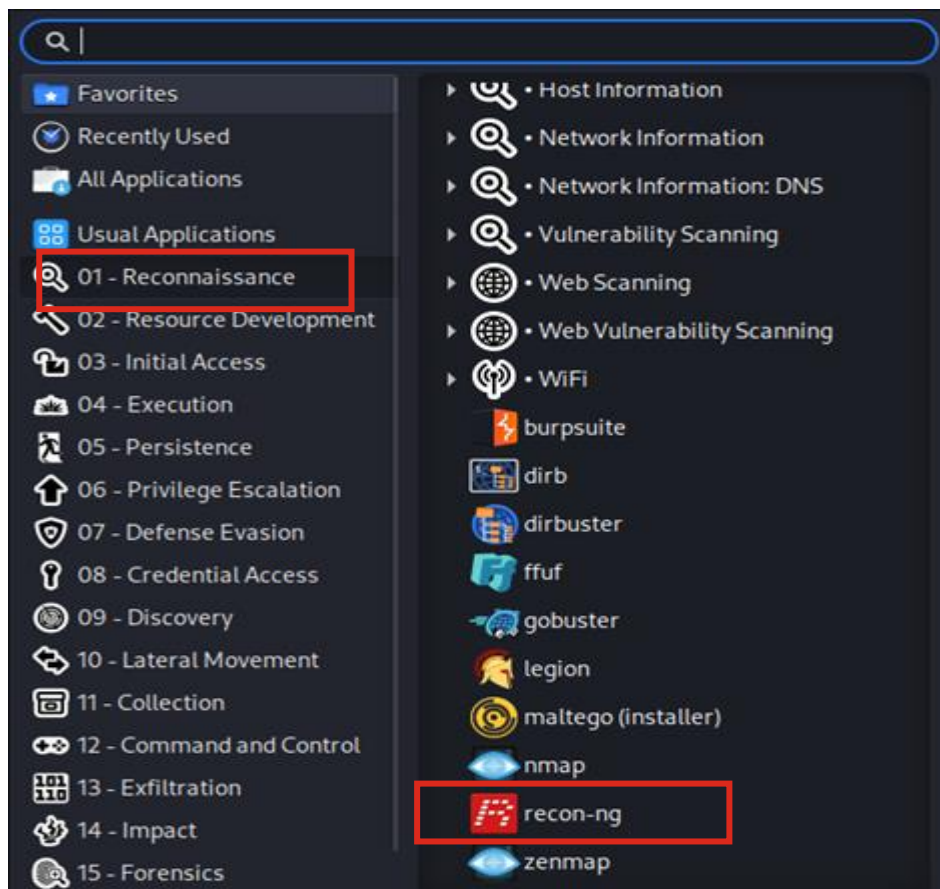
options:
-w <wordlist-file>
-r <regular-results-file>
-c <csv-results-file>
-d <delay-millisecs>
-i <ips-to-ignore> (useful if you're obtaining false positives)

e.g.:
dnsmap example.com
dnsmap example.com -w yourwordlist.txt -r /tmp/domainbf_results.txt
dnsmap example.com -r /tmp/ -d 3000
dnsmap example.com -r ./domainbf_results.txt
```




การสอดแนมแบบ : Reconnaissance

■ Recon-ng



```
[recon-ng][default] > marketplace search
```

Path	Version	Status	Updated	D	K
discovery/info_disclosure/cache_snoop	1.1	not installed	2020-10-13		
discovery/info_disclosure/interesting_files	1.2	not installed	2021-10-04		
exploitation/injection/command_injector	1.0	not installed	2019-06-24		
exploitation/injection/xpath_bruter	1.2	not installed	2019-10-08		
import/csv_file	1.1	not installed	2019-08-09		
import/list	1.1	not installed	2019-06-24		
import/masscan	1.0	not installed	2020-04-07		
import/nmap	1.1	not installed	2020-10-06		
recon/companies-contacts/bing_linkedin_cache	1.0	not installed	2019-06-24		*
recon/companies-contacts/censys_email_address	2.1	not installed	2022-01-31	*	*
recon/companies-contacts/pen	1.1	not installed	2019-10-15		
recon/companies-domains/censys_subdomains	2.1	not installed	2022-01-31	*	*
recon/companies-domains/pen	1.1	not installed	2019-10-15		
recon/companies-domains/viewdns_reverse_whois	1.1	not installed	2021-08-24		
recon/companies-domains/whoxy_dns	1.1	not installed	2020-06-17		*
recon/companies-multi/censys_org	2.1	not installed	2022-01-31	*	*
recon/companies-multi/censys_tls_subjects	2.1	not installed	2022-01-31	*	*
recon/companies-multi/github_miner	1.1	not installed	2020-05-15		*
recon/companies-multi/shodan_org	1.1	not installed	2020-07-01	*	*
recon/companies-multi/whois_miner	1.1	not installed	2019-10-15		
recon/contacts-contacts/abc	1.0	not installed	2019-10-11	*	
recon/contacts-contacts/mailtester	1.0	not installed	2019-06-24		
recon/contacts-contacts/mangle	1.0	not installed	2019-06-24		
recon/contacts-contacts/unmangle	1.1	not installed	2019-10-27		
recon/contacts-credentials/hibp_breach	1.2	not installed	2019-09-10		*

marketplace search

marketplace install recon/domains-hosts/hackertarget

modules load recon/domains-hosts/hackertarget

options set SOURCE rapid7.com

run

show hosts



การสอดแนมแบบ : Reconnaissance

■ Recon-ng

```
SOURCE => rapid7.com  
[recon-ng][default][hackertarget] > run
```

RAPID7.COM

```
[*] Country: None  
[*] Host: rapid7.com  
[*] Ip_Address: 3.170.185.102  
[*] Latitude: None  
[*] Longitude: None  
[*] Notes: None  
[*] Region: None  
[*]  
[*] Country: None  
[*] Host: 128.177.65.3.rapid7.com  
[*] Ip_Address: 128.177.65.3  
[*] Latitude: None  
[*] Longitude: None  
[*] Notes: None  
[*] Region: None  
[*]  
[*] Country: None  
[*] Host: cloud.appspider.rapid7.com  
[*] Ip_Address: 18.209.181.43  
[*] Latitude: None  
[*] Longitude: None  
[*] Notes: None  
[*] Region: None  
[*]  
[*] Country: None  
[*] Host: appspidered.rapid7.com  
[*] Ip_Address: 34.196.250.218  
[*] Latitude: None  
[*] Longitude: None
```

SUMMARY

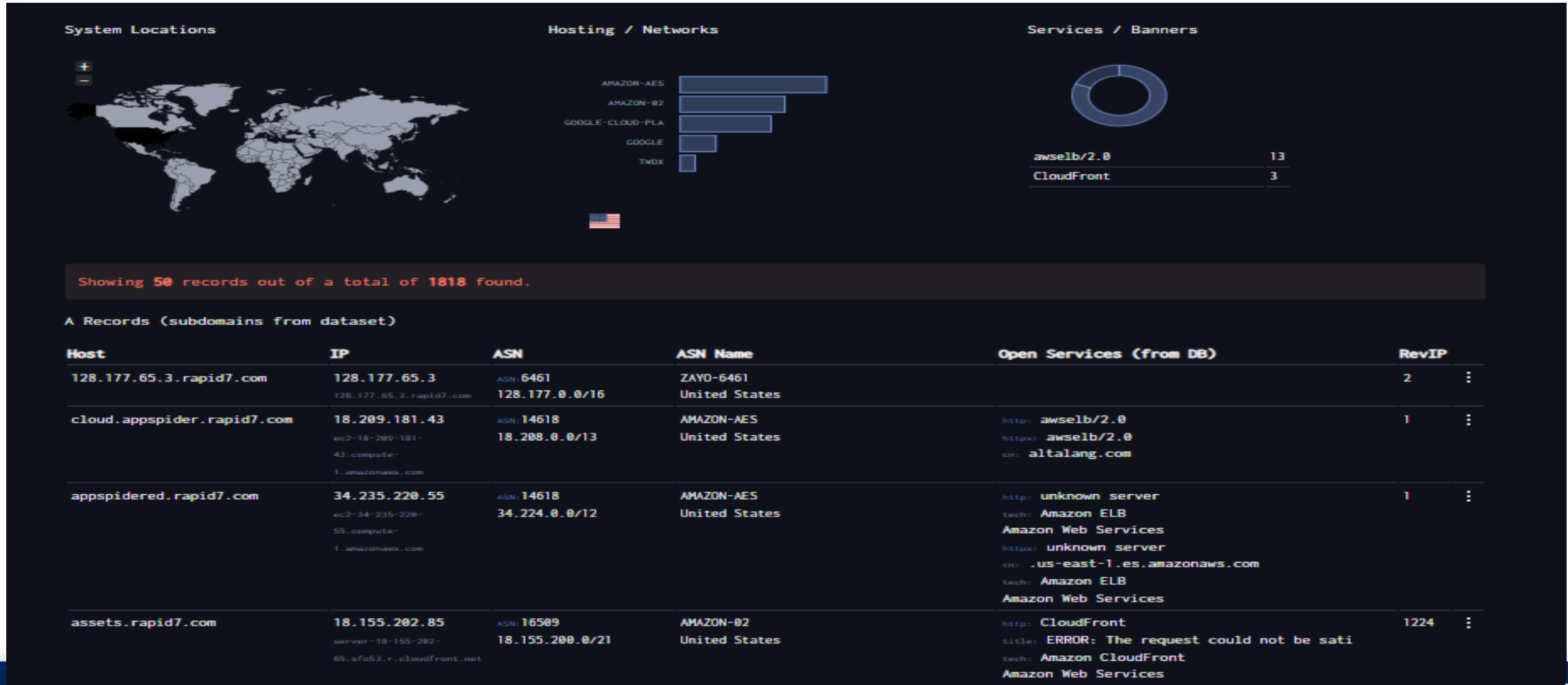
```
[*] 501 total (501 new) hosts found.  
[recon-ng][default][hackertarget] > show hosts
```

rowid	host	ip_address	region	country	latitude	longitude	notes	module
1	rapid7.com	3.170.185.102						hackertarget
2	128.177.65.3.rapid7.com	128.177.65.3						hackertarget
3	cloud.appspider.rapid7.com	18.209.181.43						hackertarget
4	appspidered.rapid7.com	34.196.250.218						hackertarget
5	web.staging.asecloud.rapid7.com	54.152.81.18						hackertarget
6	assets.rapid7.com	18.155.202.85						hackertarget
7	production.blog.corpwebsite.aws.rapid7.com	52.21.87.201						hackertarget
8	blog.rapid7.com	13.226.94.41						hackertarget
9	bounces.rapid7.com	192.28.158.130						hackertarget
10	brand.rapid7.com	3.209.0.44						hackertarget
11	casper.rapid7.com	144.121.2.40						hackertarget
12	community.rapid7.com	52.3.135.190						hackertarget
13	content.rapid7.com	98.84.69.105						hackertarget
14	argo-itsm-chatbot.corp.rapid7.com	34.121.82.70						hackertarget
15	scoping-calculator.corp.rapid7.com	35.231.252.108						hackertarget
16	de.rapid7.com	18.173.219.36						hackertarget
17	dev-lb.rapid7.com	52.52.156.56						hackertarget
18	docs.rapid7.com	99.84.160.12						hackertarget
19	dev.docs.rapid7.com	108.139.10.97						hackertarget
20	earlyaccess.rapid7.com	52.205.83.47						hackertarget
21	events.rapid7.com	52.205.83.47						hackertarget
22	experttracks.rapid7.com	52.37.174.97						hackertarget
23	extensions.rapid7.com	44.210.54.157						hackertarget
24	filetransfer.rapid7.com	208.118.227.119						hackertarget
25	komand-dev.k8s.corpwebsite.gcp.rapid7.com	34.74.146.177						hackertarget
26	komand-prod.k8s.corpwebsite.gcp.rapid7.com	34.74.146.177						hackertarget



การสอดแนมแบบ : Reconnaissance

- ❑ IP addresses, domain names, and network topology





การสอดแนมแบบ : Reconnaissance

■ osint.sh

 OSINT.SH

HOME ALL TOOLS ▾ ABOUT API TERMS CONTACT SPONSOR

SUBDOMAIN FINDER

The fastest way to discover subdomains in your DNS recon

CHECK NOW

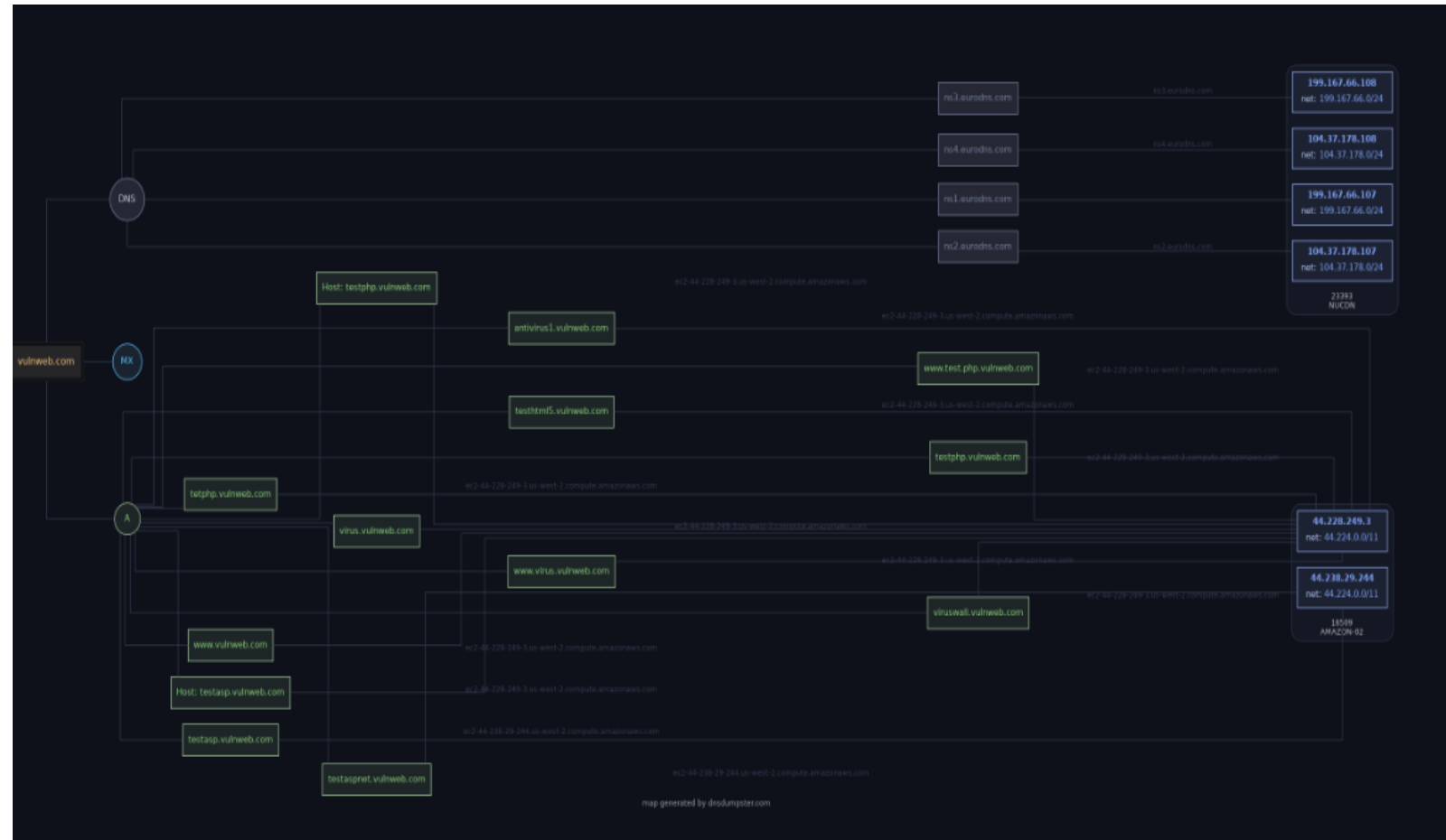
1	testmetasploitable.vulnweb.com	44.228.249.3	.
2	club.vulnweb.com	44.228.249.3	.
3	class.vulnweb.com	44.228.249.3	.
4	mpk.vulnweb.com	44.228.249.3	.
5	baidu.vulnweb.com	44.228.249.3	.
6	poc-beer.timestream.us-east-1.vulnweb.com	44.228.249.3	.
7	testarsp.vulnweb.com	44.228.249.3	.
8	ftestasp.vulnweb.com	44.228.249.3	.
9	php.vulnweb.com	44.228.249.3	.
10	htttestphp.vulnweb.com	44.228.249.3	.



การสอดแนมแบบ : Reconnaissance



กิจกรรมที่ 7 ทดสอบการ Reconnaissance vulnweb.com





ลงทะเบียนอบรม



วันที่ 4 พฤศจิกายน 2568 รอบเช้า



การสอดแนมแบบ : Reconnaissance

■ OSINT

- ❑ Open-source intelligence (OSINT) is data collected from
 - ❑ **publicly available sources** to be used in an intelligence context.
 - ❑ In the intelligence community, the term **"open" refers to overt**, publicly available sources (as opposed to covert or clandestine sources).
 - ❑ It is **not related to open-source software or public intelligence**.





การสอดแนมแบบ : Reconnaissance

■ OSINT

- ❑ **OSINT sources** can be divided up into six different categories of information flow:[3]
 - ❑ **Media:**, print newspapers, magazines, radio, and television from across and between countries.
 - ❑ **Internet**, online publications, blogs, discussion groups, citizen media (i.e. – cell phone videos, and user created content), YouTube, and other social media websites (i.e. – Facebook, Twitter, Instagram, etc.). This source also outpaces a variety of other sources due to its timeliness and ease of access.
 - ❑ **Public Government Data**, public government reports, budgets, hearings, telephone directories, press conferences, websites, and speeches. Although this source comes from an official source they are publicly accessible and may be used openly and freely.
 - ❑ **Professional and Academic Publications**, information acquired from journals, conferences, symposia, academic papers, dissertations, and theses.
 - ❑ **Commercial Data**, commercial imagery, financial and industrial assessments, and databases.
 - ❑ **Grey literature**, technical reports, preprints, patents, working papers, business documents, unpublished works, and newsletters.



การสอดแนมแบบ : Reconnaissance

■ OSINT

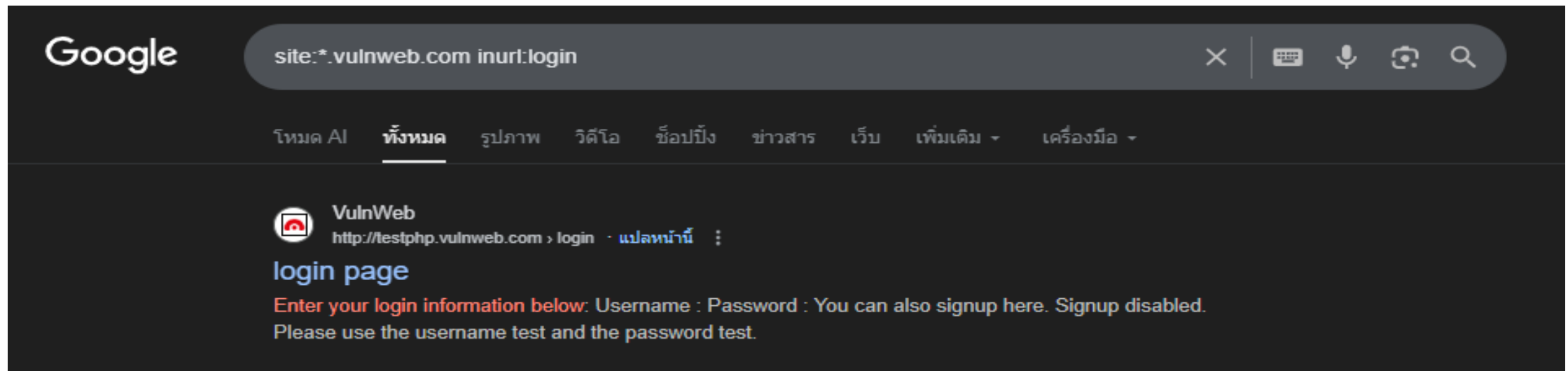
- ☐ Methods of OSINT Into Deep Search
 - ☐ **Web Directories** – WWW Library and Internet Public Library
 - ☐ **Search Engines** – Google, Yahoo, Bing, Baidu, MSN etc. etc.
 - ☐ **Important Engine** – Wolframe Alpha
 - ☐ **Serial Search Engines** – Soolve , myallsearch
 - ☐ **Hardware Search Engine** – Shodan
 - ☐ **Scientific Search Engine** – Google Scholar, Academia
 - ☐ **Encyclopedia** – Wikipedia
 - ☐ **Book Stores** – Amazon, Google Books etc.
 - ☐ **Translations** – Google, Bing and many more
 - ☐ **Aeronautical** – flightradar24.com and many more
 - ☐ **Blogs** – Blogspot, Wordpress and many more



การสอดแนมแบบ : Reconnaissance

- OSINT : Google Hacking / Google Dorking

Google hacking (sometimes called Google dorking) is when hackers use search engines to identify security vulnerabilities. With a bit of time and search know-how, a hacker could figure out the best way to attack you.





การสอดแนมแบบ : Reconnaissance

■ OSINT : Google Hacking / Google Dorking

Google Search Operators

Working

Search operator	What it does	Example
<code>" "</code>	Search for results that mention a word or phrase.	<code>"steve jobs"</code>
<code>OR</code>	Search for results related to X or Y.	<code>jobs OR gates</code>
<code> </code>	Same as <code>OR</code> :	<code>jobs gates</code>
<code>AND</code>	Search for results related to X and Y.	<code>jobs AND gates</code>
<code>-</code>	Search for results that don't mention a word or phrase.	<code>jobs -apple</code>
<code>*</code>	Wildcard matching any word or phrase.	<code>steve * apple</code>
<code>()</code>	Group multiple searches.	<code>(ipad OR iphone) apple</code>
<code>define:</code>	Search for the definition of a word or phrase.	<code>define:entrepreneur</code>

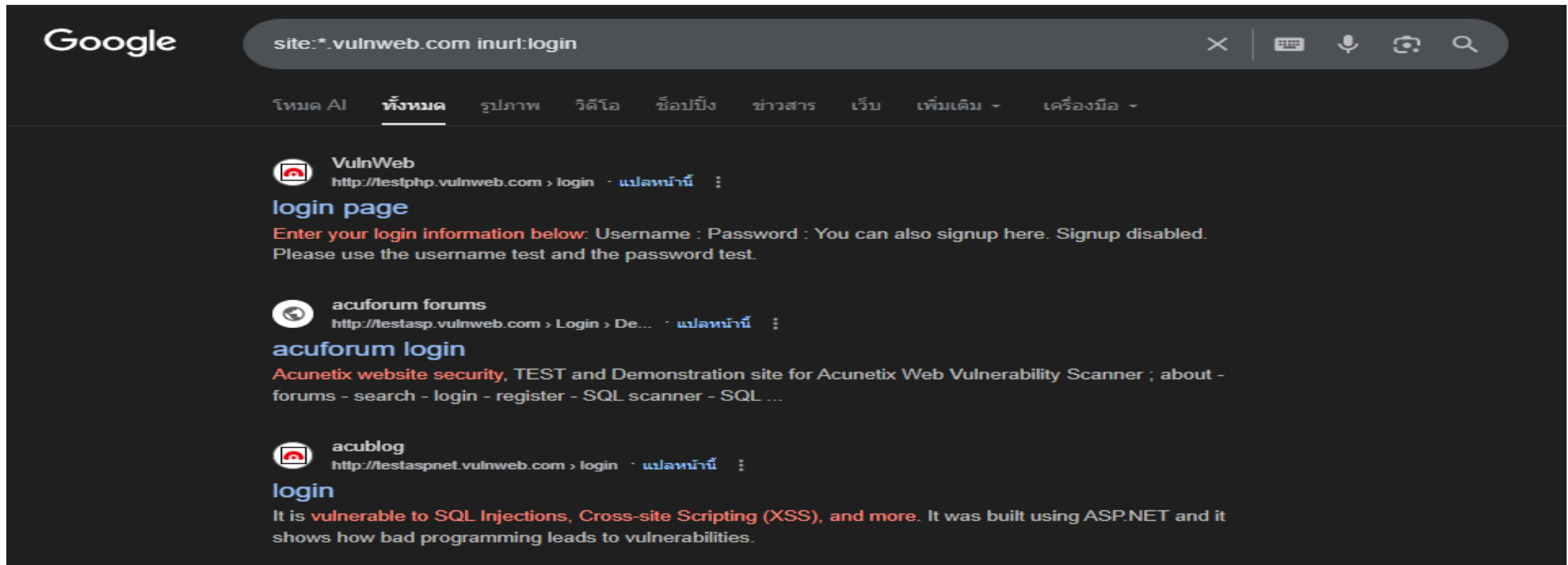
<code>filetype:</code>	Search for particular types of files (e.g., PDF).	<code>apple filetype:pdf</code>
<code>ext:</code>	Same as <code>filetype:</code>	<code>apple ext:pdf</code>
<code>site:</code>	Search for results from a particular website.	<code>site:apple.com</code>
<code>related:</code>	Search for sites related to a given domain.	<code>related:apple.com</code>
<code>intitle:</code>	Search for pages with a particular word in the title tag.	<code>intitle:apple</code>
<code>allintitle:</code>	Search for pages with multiple words in the title tag.	<code>allintitle:apple iphone</code>
<code>inurl:</code>	Search for pages with a particular word in the URL.	<code>inurl:apple</code>
<code>allinurl:</code>	Search for pages with multiple words in the URL.	<code>allinurl:apple iphone</code>
<code>intext:</code>	Search for pages with a particular word in their content.	<code>intext:apple iphone</code>



การสอดแนมแบบ : Reconnaissance

- OSINT : Google Hacking / Google Dorking

Google Search Operators `site:*.vulnweb.com inurl:login`





การสอดแนมแบบ : Reconnaissance



■ OSINT : Google Hacking / Google Dorking



EXPLOIT
DATABASE



Google Hacking Database

Show 15

Quick Search

Filters

Reset All

Date Added	Dork	Category	Author
2024-08-23	site:github.com "BEGIN OPENSSSH PRIVATE KEY"	Files Containing Passwords	kstrawn0
2024-08-23	ext:nix "BEGIN OPENSSSH PRIVATE KEY"	Files Containing Passwords	kstrawn0
2024-07-26	inurl:home.htm intitle:1766	Various Online Devices	Kishoreram
2024-07-04	intitle:"SSL Network Extender Login" -checkpoint.com	Vulnerable Servers	Everton Hydd3n
2024-07-04	intext:"siemens" & inurl: "/portal/portal.mwsl"	Vulnerable Servers	Kishoreram
2024-07-04	Google Dork Submission For GlobalProtect Portal	Vulnerable Servers	Gurudatt Choudhary
2024-07-04	inurl:"cgi-bin/koha"	Vulnerable Servers	Hilary Soita
2024-07-04	intext:"aws_access_key_id" intext:"aws_secret_access_key" filetype:json filetype:yaml	Files Containing Passwords	Joel Indra
2024-07-04	intext:"proftpd.conf" "index of"	Files Containing Juicy Info	Fernando Mengali
2024-07-04	site:.edu filetype:xls "root" database	Files Containing Juicy Info	defaultredmode
2024-07-04	intitle:index of /etc/ssh	Files Containing Passwords	Shivam Dhingra

<https://www.exploit-db.com/google-hacking-database>

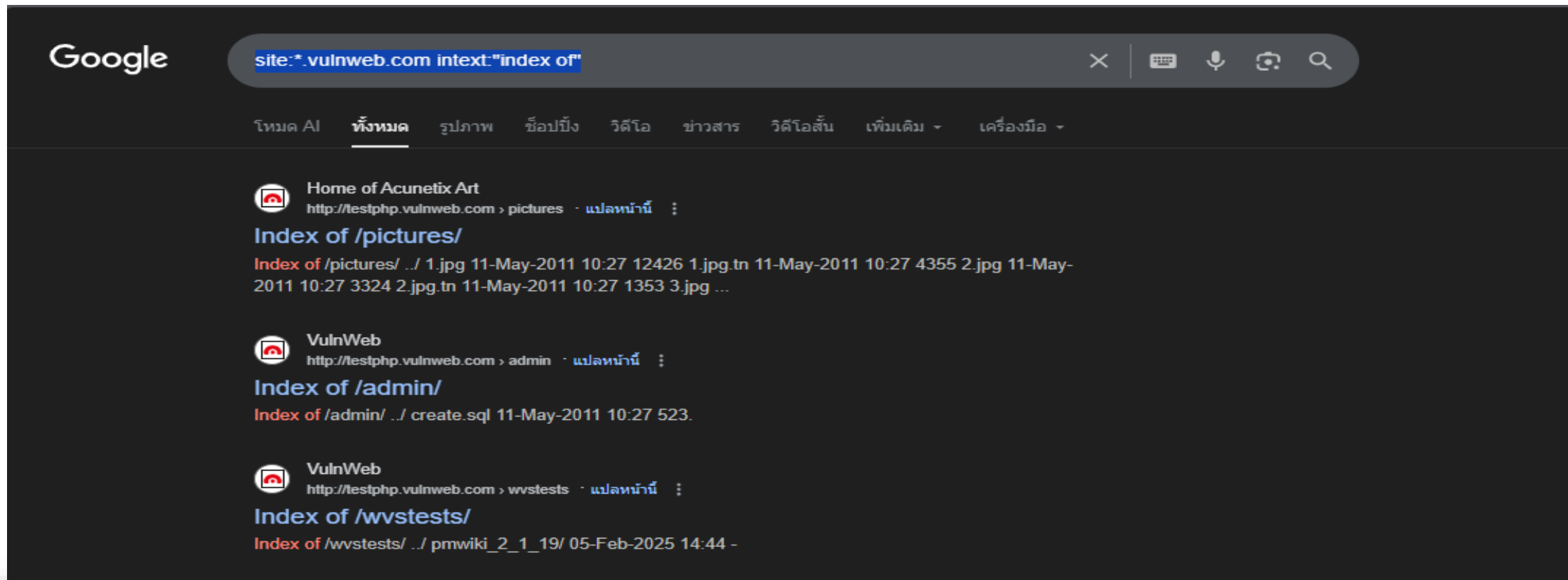




การสอดแนมแบบ : Reconnaissance

- OSINT : Google Hacking / Google Dorking

Google Search Operators `site:*.vulnweb.com intext:"index of"`

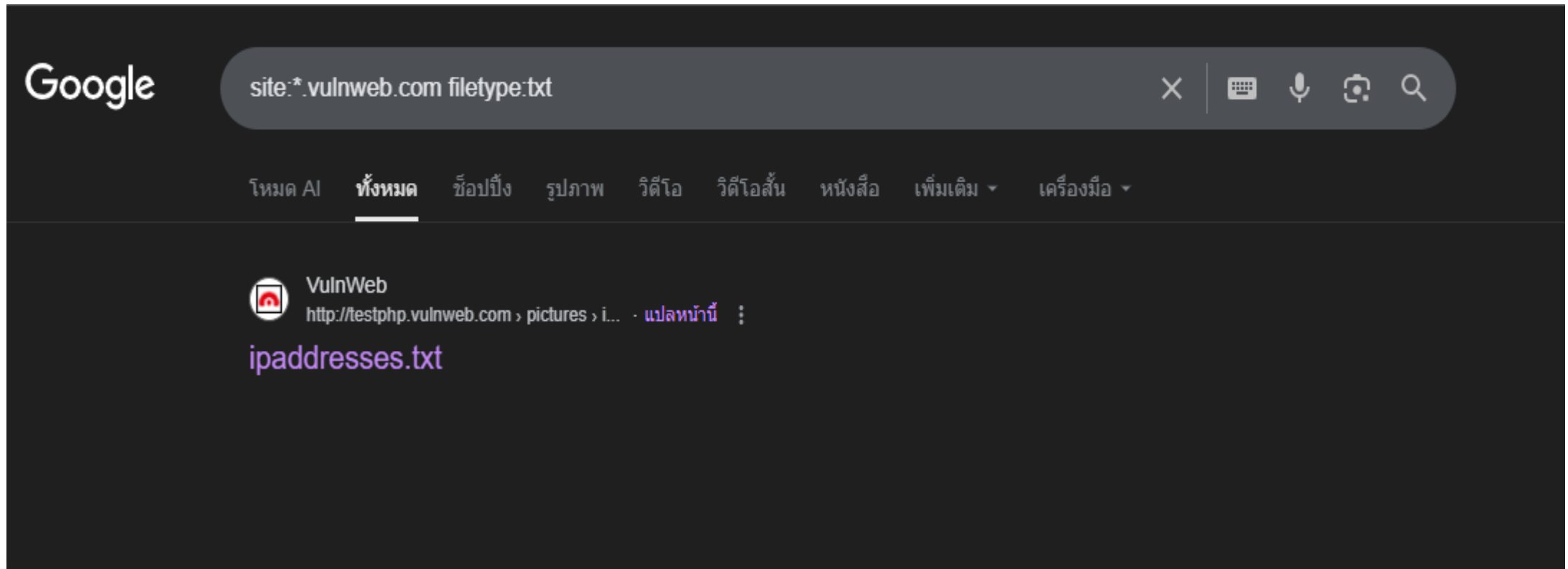




การสอดแนมแบบ : Reconnaissance

- OSINT : Google Hacking / Google Dorking

Google Search Operators site:*.vulnweb.com filetype:txt





การสอดแนมแบบ : Reconnaissance

OSINT : Google Hacking / Google Dorking

Google Search Operators site:*.vulnweb.com filetype:bak

```
1 <?PHP require_once("database_connect.php"); ?>
2 <!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN"
3 "http://www.w3.org/TR/html4/loose.dtd">
4 <html><!-- InstanceBegin template="/Templates/main_dynamic_template.dwt.php" codeOutsideHTMIsLocked="
5 <head>
6 <meta http-equiv="Content-Type" content="text/html; charset=iso-8859-2">
7
8 <!-- InstanceBeginEditable name="document_title_rgn" -->
9 <title>Home of WASP Art</title>
10 <!-- InstanceEndEditable -->
11 <link rel="stylesheet" href="style.css" type="text/css">
12 <!-- InstanceBeginEditable name="headers_rgn" -->
13 <!-- here goes headers headers -->
14 <!-- InstanceEndEditable -->
15 <script language="JavaScript" type="text/JavaScript">
16 <!--
17 function MM_reloadPage(init) { //reloads the window if Nav4 resized
18 if (init==true) with (navigator) {if ((appName=="Netscape")&&(parseInt(appVersion)==4)) {
19 document.MM_pgW=innerWidth; document.MM_pgH=innerHeight; onresize=MM_reloadPage; }}
20 else if (innerWidth!=document.MM_pgW || innerHeight!=document.MM_pgH) location.reload();
21 }
22 MM_reloadPage(true);
23 //-->
24 </script>
25
26 </head>
27 <body>
28 <div id="mainLayer" style="position:absolute; width:700px; z-index:1">
29 <div id="masthead">
30 <h1 id="siteName">ACUNETIX ART</h1>
31 <h6 id="siteInfo">TEST and Demonstration site for Acunetix Web Vulnerability Scanner</h6>
32 <div id="globalNav">
```



การสอดแนมแบบ : Reconnaissance

■ OSINT : Shodan

The screenshot shows the Shodan website homepage. At the top, there is a navigation bar with links: Shodan, Maps, Images, Monitor, Developer, and More... Below this is a dark header with the SHODAN logo, links for Explore and Pricing, a search bar with the placeholder text 'Type / to search', and a red search button. A green 'Login' button is in the top right corner. The main content area features the headline 'Search Engine for the Internet of Everything' and a subtext: 'Shodan is the world's first search engine for Internet-connected devices. Discover how Internet intelligence can help you make better decisions.' Below this is a green 'SIGN UP NOW' button. To the right of the text is a world map with colorful heatspots indicating device density. At the bottom, there is a section titled '// EXPLORE THE PLATFORM' with three cards: 'Beyond the Web' (describing discovery of power plants, mobile phones, etc.), 'Monitor Network Exposure' (describing tracking of devices), and 'Internet Intelligence' (describing data-driven views of technology).



การสอดแนมแบบ : Reconnaissance



■ OSINT : Shodan

The screenshot shows the Shodan search results for the IP address 44.228.249.3. The interface includes a search bar with the IP address and a magnifying glass icon. Below the search bar, there are tabs for 'Regular View', 'Raw Data', 'Timeline', and 'Whois'. The main content area displays a satellite map of the location, with the IP address 44.228.249.3 prominently displayed. To the right of the map, there is a section for 'General Information' which lists various details about the host, including hostnames, domains, cloud provider, region, service, country, city, and organization.

General Information	
Hostnames	ec2-44-228-249-3.us-west-2.compute.amazonaws.com
Domains	amazonaws.com
Cloud Provider	Amazon
Cloud Region	us-west-2
Cloud Service	EC2
Country	United States
City	Boardman
Organization	Amazon.com, Inc.

This section displays additional search results for the IP address 44.228.249.3, specifically focusing on vulnerabilities and open ports. The 'Web Technologies' section lists 'Reverse Proxies' and 'Web Servers', both identified as Nginx 1.19.0. The 'Vulnerabilities' section shows a list of CVEs, including CVE-2023-44487, CVE-2021-23017, and CVE-2021-3618, each with a brief description of the vulnerability. The 'Open Ports' section shows a list of open ports, including port 80 (TCP).

Web Technologies

- Reverse Proxies: Nginx 1.19.0
- Web Servers: Nginx 1.19.0

Vulnerabilities

Note: the device may not be impacted by all of these issues. The vulnerabilities are implied based on the software and version.

2023 (1)

- CVE-2023-44487** **75** The HTTP/2 protocol allows a denial of service (server resource consumption) because request cancellation can reset many streams quickly, as exploited in the wild in August through October 2023.

2021 (2)

- CVE-2021-23017** **77** A security issue in nginx resolver was identified, which might allow an attacker who is able to forge UDP packets from the DNS server to cause 1-byte memory overwrite, resulting in worker process crash or potential other impact.
- CVE-2021-3618** **74** ALPACA is an application layer protocol content confusion attack, exploiting TLS servers implementing different protocols but using compatible certificates, such as multi-domain or wildcard certificates. A MiTM attacker having access to victim's traffic at the TCP/IP layer can redirect traffic from one subdomain to another, resulting in a valid TLS session. This breaks the authentication of TLS and cross-protocol attacks may be possible where the behavior of one protocol service may compromise the other at the application layer.

Open Ports

- 80

// 80 / TCP

nginx 1.19.0

Acunetix Web Vulnerability Scanner - Test we

HTTP/1.1 200 OK
Server: nginx/1.19.0
Date: Sun, 02 Nov 2025 05:29:19 GMT
Content-Type: text/html
Content-Length: 4018
Last-Modified: Tue, 28 Jul 2020 09:20:49 GMT
Connection: keep-alive
ETag: "5f1fedf1-fb2"
Accept-Ranges: bytes

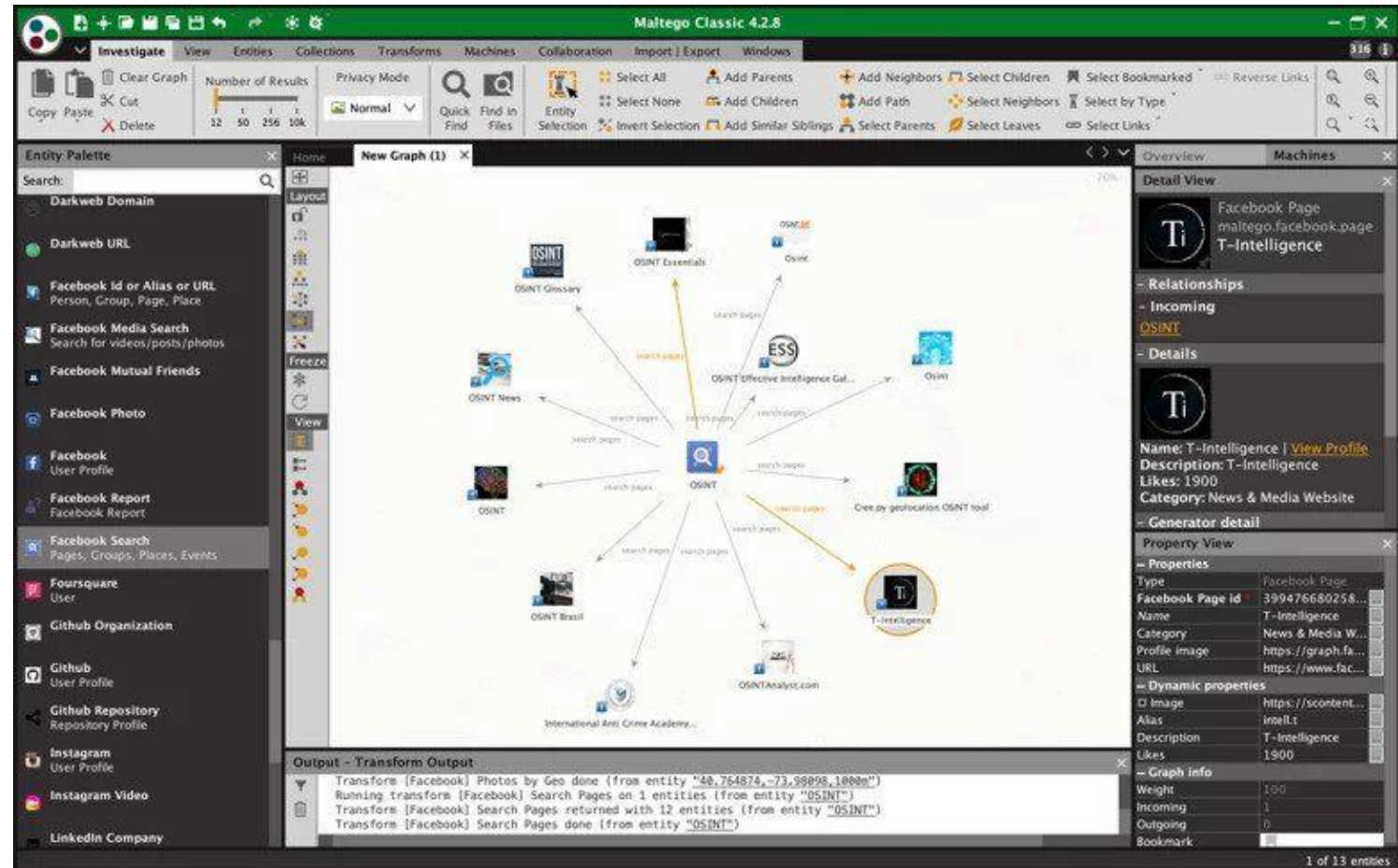
<https://www.shodan.io/>





การสอดแนมแบบ : Reconnaissance

■ OSINT : maltego





การสอดแนมแบบ : Reconnaissance

OSINT : maltego

The screenshot shows the Maltego Community Edition 4.2.1 interface. The main window displays a complex network graph with nodes and edges. The interface is divided into several panes:

- Entity Palette (Left):** Lists various entity types such as Company, DNS Name, Email Address, Image, Cryptocurrency (Bitcoin Address, Ethereum Address), and Devices (Desktop Computer, Mobile Computer, Mobile Phone, Smartphone). A red label "Entity" is placed over this pane.
- Main Windows (Center):** The large central area displaying the network graph. A red label "Main Windows" is placed over this area.
- Overview (Top Right):** A smaller version of the network graph. A red label "Overview" is placed over this pane.
- Detail View (Bottom Right):** A pane showing detailed information about a selected entity. It includes a table of entities and a section for properties. A red label "Detail" is placed over this pane.
- Property View (Bottom Right):** A pane showing the properties of a selected entity. A red label "Property" is placed over this pane.
- Output (Bottom Center):** A pane for displaying the results of the investigation. A red label "Output" is placed over this pane.
- Menu (Top Left):** The top-left corner of the application window. A red label "Menu" is placed over this area.
- Run (Bottom Left):** The bottom-left corner of the application window. A red label "Run" is placed over this area.

The network graph in the main window shows a complex web of connections between various entities, including IP addresses, email addresses, and domains. A red label "Entity" is also placed over the main graph area.

Entity	Type	Value
v=spf1 a mx ip4:202.149	IPv4 Address	1 12 2...
v=spf1 include:sendgrid	AS	1 13 1...
v=spf1 ip4:202.149	Phone Number	1 18 300
_globalsign-domain-verify	BuiltWith Relationship	1 13 192
1337DAY-ID-32112	BuiltWith Technology	1 0 100
AKAMABLOG-F6B7D358	MX Record	1 0 100

Property	Value
Type	Vulnerability
Vulnerability	AKAMABLOG-F6B7D3...
Bulletin Family	blog
Description	no sign of p.../blogs...
URL	http://security.google...
ID	AKAMABLOG-F6B7D3...
Published At	2019-02-07T18:30:00
Title	Protecting your...

35 of 636 entities





การสอดแนมแบบ : Reconnaissance

- OSINT : maltego

Start Maltego

Beginners' Guide | Setting up Maltego Graph
Community Edition (CE)





การสอดแนมแบบ : Reconnaissance

■ OSINT : maltego

- ☐ **Entity** : An entity is a piece of data which is taken as an input to extract further information.
 - ☐ domain name xyz.com
 - ☐ IP Address
 - ☐ E Mail Address
 - ☐ Mobile Number
 - ☐ Company
 - ☐ Exploit
 - ☐ Vulnerability
- ☐ **Transform**: A piece of code which takes an entity (or a group of entities) as an input and extracts data in the form of entity (or entities) based upon the relationship.
 - ☐ DomainToDNSNameSchema: this transform will try to test various name schemas against a domain (entity).
- ☐ **Machine**: A machine is basically a set of transforms linked programmatically.
 - ☐ Footprint L1: a transform which takes a domain as an input and generates various types of information related to the organization such as emails, AS number etc.



การสอดแนมแบบ : Reconnaissance

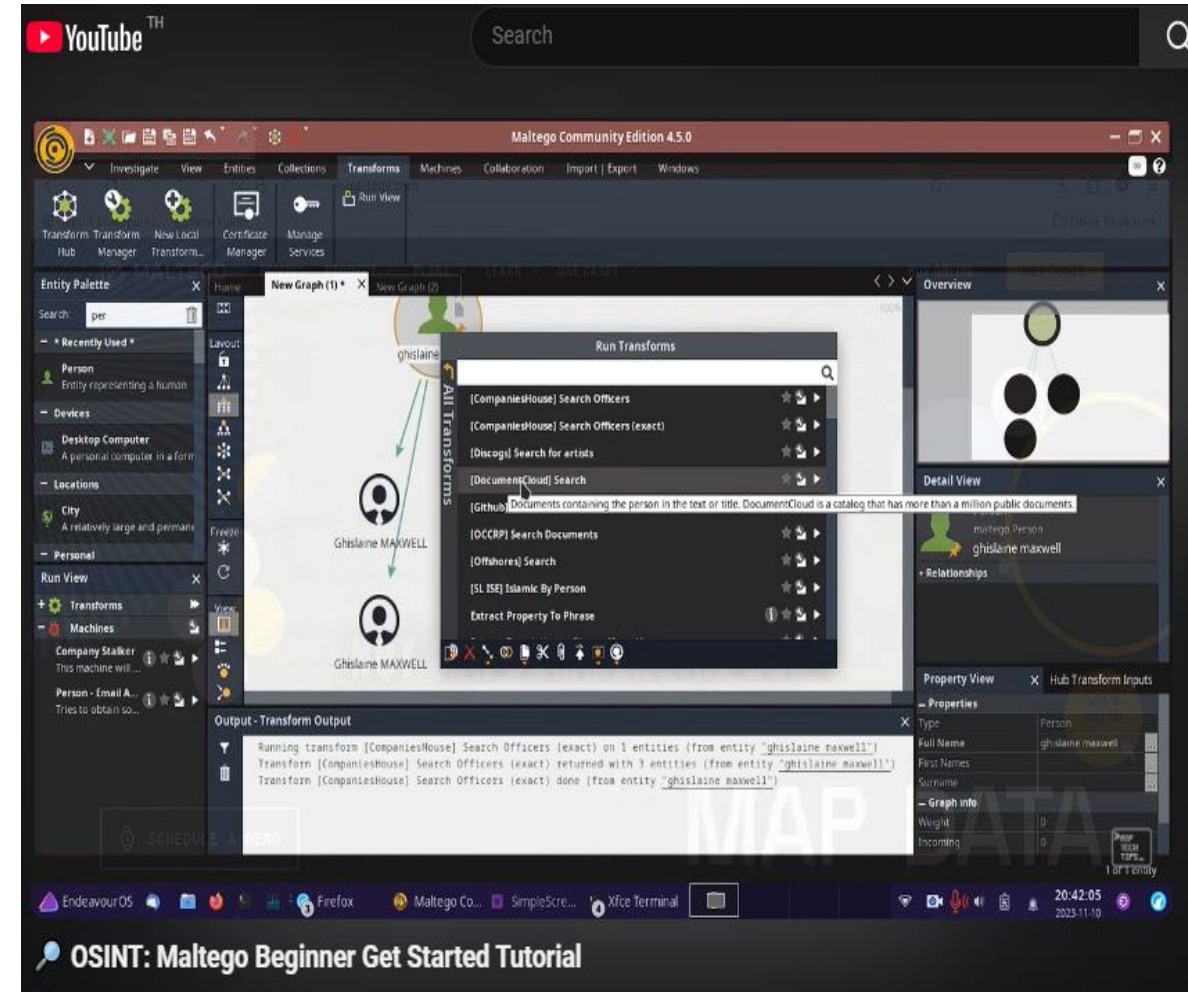
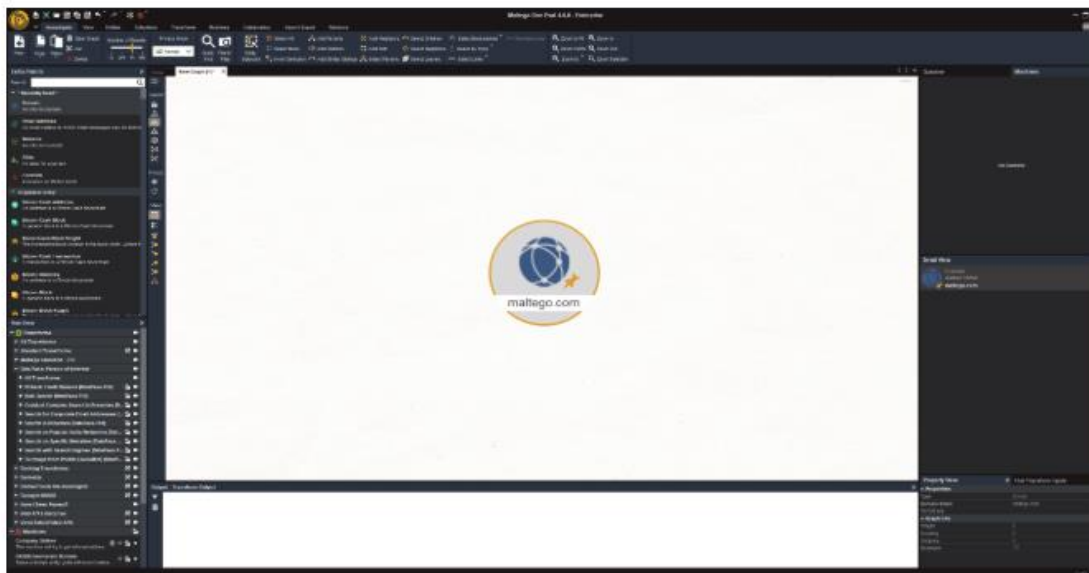
■ OSINT : maltego

Maltego Tutorial

Step 1: Creating Our First Entity in Maltego

In this guide, we will use GNU organization as an example, which is identified by the domain **gnu[.]org**.

To add an Entity for this domain to the graph, we first search for the **Domain Entity** in the Entity Palette, which is on the left of the window, and drag a new Entity onto the graph.





การสอดแนมแบบ : Reconnaissance

- Python HTTP Server



กิจกรรมที่ 8
ทดสอบการ OSINT

vulnweb.com
demo.testfire.net

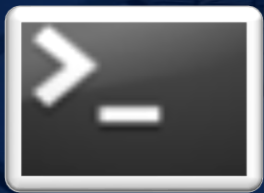




ลงทะเบียนอบรม



วันที่ 4 พฤศจิกายน 2568 รอบบ่าย



Active Reconnaissance



การสอดแนมแบบ : Reconnaissance

■ nmap

```
HOST DISCOVERY:
-sL: List Scan - simply list targets to scan
-sn: Ping Scan - disable port scan
-Pn: Treat all hosts as online -- skip host discovery
-PS/PA/PU/PY[portlist]: TCP SYN/ACK, UDP or SCTP discovery to given ports
-PE/PP/PM: ICMP echo, timestamp, and netmask request discovery probes
-PO[protocol list]: IP Protocol Ping
-n/-R: Never do DNS resolution/Always resolve [default: sometimes]
--dns-servers <serv1[,serv2],...>: Specify custom DNS servers
--system-dns: Use OS's DNS resolver
--traceroute: Trace hop path to each host

SCAN TECHNIQUES:
-sS/sT/sA/sW/sM: TCP SYN/Connect()/ACK/Window/Maimon scans
-sU: UDP Scan
-sN/sF/sX: TCP Null, FIN, and Xmas scans
--scanflags <flags>: Customize TCP scan flags
-sI <zombie host[:probeport]>: Idle scan
-sY/sZ: SCTP INIT/COOKIE-ECHO scans
-sO: IP protocol scan
-b <FTP relay host>: FTP bounce scan
```




การสอดแนมแบบ : Reconnaissance

■ nmap

```
PORT SPECIFICATION AND SCAN ORDER:
-p <port ranges>: Only scan specified ports
  Ex: -p22; -p1-65535; -p U:53,111,137,T:21-25,80,139,8080,S:9
--exclude-ports <port ranges>: Exclude the specified ports from scanning
-F: Fast mode - Scan fewer ports than the default scan
-r: Scan ports consecutively - don't randomize
--top-ports <number>: Scan <number> most common ports
--port-ratio <ratio>: Scan ports more common than <ratio>
SERVICE/VERSION DETECTION:
-sV: Probe open ports to determine service/version info
--version-intensity <level>: Set from 0 (light) to 9 (try all probes)
--version-light: Limit to most likely probes (intensity 2)
--version-all: Try every single probe (intensity 9)
--version-trace: Show detailed version scan activity (for debugging)
SCRIPT SCAN:
-sC: equivalent to --script=default
--script=<Lua scripts>: <Lua scripts> is a comma separated list of
  directories, script-files or script-categories
--script-args=<n1=v1,[n2=v2,...]>: provide arguments to scripts
--script-args-file=filename: provide NSE script args in a file
--script-trace: Show all data sent and received
--script-updatedb: Update the script database.
--script-help=<Lua scripts>: Show help about scripts.
  <Lua scripts> is a comma-separated list of script-files or
  script-categories.
OS DETECTION:
-O: Enable OS detection
--osscan-limit: Limit OS detection to promising targets
--osscan-guess: Guess OS more aggressively
```



การสอดแนมแบบ : Reconnaissance

■ nmap

```
kali# nmap 10.10.10.20 -Pn -O -A -p- -vv
```

```
kali# nmap 10.10.10.0/24 -Pn -O -A -p- -vv
```

```
root@osboxes:~# nmap 192.168.200.131 -Pn -O -A -p- -vv

Starting Nmap 7.60 ( https://nmap.org ) at 2018-04-18 07:50 EDT
NSE: Loaded 146 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 2) scan.
Initiating NSE at 07:50
Completed NSE at 07:50, 0.00s elapsed
NSE: Starting runlevel 2 (of 2) scan.
Initiating NSE at 07:50
Completed NSE at 07:50, 0.00s elapsed
Initiating ARP Ping Scan at 07:50
Scanning 192.168.200.131 [1 port]
Completed ARP Ping Scan at 07:50, 0.22s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 07:50
Completed Parallel DNS resolution of 1 host. at 07:50, 0.00s elapsed
Initiating SYN Stealth Scan at 07:50
Scanning 192.168.200.131 (192.168.200.131) [65535 ports]
Discovered open port 25/tcp on 192.168.200.131
Discovered open port 53/tcp on 192.168.200.131
Discovered open port 23/tcp on 192.168.200.131
Discovered open port 80/tcp on 192.168.200.131
Discovered open port 5900/tcp on 192.168.200.131
```



การสอดแนมแบบ : Reconnaissance

- arp scan

```
kali# arp-scan 192.168.0.1/24
```

```
root@kali: ~  
File Edit View Search Terminal Help  
root@kali:~# arp-scan 192.168.0.1/24  
Interface: eth0, datalink type: EN10MB (Ethernet)  
WARNING: host part of 192.168.0.1/24 is non-zero  
Starting arp-scan 1.9 with 256 hosts (http://www.nta-monitor.com/tools/arp-scan/)  
192.168.0.1      3c:df:a9:68:e6:55      (Unknown)  
192.168.0.6      60:03:08:64:d5:c3      (Unknown)  
192.168.0.7      00:23:df:fa:e7:93      Apple, Inc  
192.168.0.10     6c:40:08:8c:d9:30      (Unknown)  
192.168.0.3      c4:36:6c:ac:98:70      (Unknown)  
192.168.0.4      c4:36:6c:ac:98:70      (Unknown)  
192.168.0.11     a4:5e:60:28:45:02      (Unknown)  
  
7 packets received by filter, 0 packets dropped by kernel  
Ending arp-scan 1.9: 256 hosts scanned in 2.704 seconds (94.67 hosts/sec). 7 responded  
root@kali:~#
```




การสอดแนมแบบ : Reconnaissance

- Service Fingerprint `kali# nmap 10.10.10.20 -Pn -O -A -p- -vv`

```
PORT      STATE SERVICE      REASON          VERSION
21/tcp    open  ftp          syn-ack ttl 64  vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_   Connected to 192.168.200.140
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   vsFTPD 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          syn-ack ttl 64  OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_ssh-dss AAAAB3NzaC1kc3MAAACBALz4hsc8a2Srq4nlW960qV8xwBG0JC+jI7fWxm5METIJH4tKr/xUTwsTYI
wSIXSUajnU5oWmY5x85sBw+XDAAAFQDFkMpmDFQTF+oRqaoSNVU7Z+hjSwAAAIBCQxNKzi1TyP+QJIFa3M0oLqQ
+Y4dp0lzfWHwZ/jzHwtuaDQaok7ulF9711EazeJLqfiWrAzoklqSWyDQJAAAAIA1lAD3xWYkeIeHv/R3P9i+Xao
k/YRnjzx1EAYBsvCmM4a0jmhZ0oNiRWlc/F+bkUeFKrBx/D2fdfZmhrGg==
|_   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
|_ssh-rsa AAAAB3NzaC1yc2EAAAABIWAAQEAAstqnuFMBOZvO3WTEjp4TUDjgWkIVNdTq6kboEDjteOfc65TlI
pmkJcVgETJ5WhKObUNf1AKZW++4Xlc63M4KI5cjvMMIPEVOyR3AKmI78Fo3HJjYucg87JjLeC66I7+d1EYX6zT8
qi2YXbhvwIJ0gFMb6wfe5cnQew==
23/tcp    open  telnet      syn-ack ttl 64  Linux telnetd
25/tcp    open  smtp        syn-ack ttl 64  Postfix smtpd
```



การสอดแนมแบบ : Reconnaissance

■ Web Server Fingerprint

Request

Raw Params Headers Hex

```
GET /bWAPP/sqli_10-2.php?title=Incr%'+or+title+like+'%Knig
HTTP/1.1
Host: 10.24.0.247
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; rv:50.0)
Gecko/20100101 Firefox/50.0
Accept: application/json, text/javascript, */*; q=0.01
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
X-Requested-With: XMLHttpRequest
Referer: http://10.24.0.247/bWAPP/sqli_10-1.php
Cookie: PHPSESSID=bdoa26mt04ihs2v49vtpr7kol4; security_level=0
```

Response

Raw Headers Hex

```
HTTP/1.1 200 OK
Server: nginx/1.4.6 (Ubuntu)
Date: Thu, 08 Dec 2016 23:55:28 GMT
Content-Type: text/json; charset=utf-8
Content-Length: 509
Connection: close
X-Powered-By: PHP/5.5.9-1ubuntu4.20
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate,
Pragma: no-cache
```



การสอดแนมแบบ : Reconnaissance

- Web Server Fingerprint `kali# nikto -host vulnweb.com`

```
(kali@ kali)-[~]  
$ nikto -host vulnweb.com  
- Nikto v2.5.0  
-----  
+ Target IP: 44.228.249.3  
+ Target Hostname: vulnweb.com  
+ Target Port: 80  
+ Start Time: 2025-11-02 02:48:15 (GMT-5)  
-----  
+ Server: nginx/1.19.0  
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the  
+ //www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
+ No CGI Directories found (use '-C all' to force check all possible dirs)  
+ ERROR: Error limit (20) reached for host, giving up. Last error: error reading HTTP response  
+ Scan terminated: 20 error(s) and 2 item(s) reported on remote host  
+ End Time: 2025-11-02 02:49:49 (GMT-5) (94 seconds)  
-----  
+ 1 host(s) tested
```




การสอดแนมแบบ : Reconnaissance

■ Fingerprint – Exploit Mapping kali# *searchsploit* *nginx*

```
(kali@ kali)~[~]
$ searchsploit nginx
```

Exploit Title	Path
Ingress-NGINX 4.11.0 - Remote Code Execution (RCE)	multiple/remote/52338.txt
Nginx (Debian Based Distros + Gentoo) - 'logrotate' Local Privilege Escalation	linux/local/40768.sh
Nginx 0.6.36 - Directory Traversal	multiple/remote/12804.txt
Nginx 0.6.38 - Heap Corruption	linux/local/14830.py
Nginx 0.6.x - Arbitrary Code Execution NullByte Injection	multiple/webapps/24967.txt
Nginx 0.7.0 < 0.7.61 / 0.6.0 < 0.6.38 / 0.5.0 < 0.5.37 / 0.4.0 < 0.4.14 - Denial of Service (PoC)	linux/dos/9901.txt
Nginx 0.7.61 - WebDAV Directory Traversal	multiple/remote/9829.txt
Nginx 0.7.64 - Terminal Escape Sequence in Logs Command Injection	multiple/remote/33490.txt
Nginx 0.7.65/0.8.39 (dev) - Source Disclosure / Download	windows/remote/13822.txt
Nginx 0.8.36 - Source Disclosure / Denial of Service	windows/remote/13818.txt
Nginx 1.1.17 - URI Processing SecURiTy Bypass	multiple/remote/38846.txt
Nginx 1.20.0 - Denial of Service (DOS)	multiple/remote/50973.py
Nginx 1.3.9 < 1.4.0 - Chunked Encoding Stack Buffer Overflow (Metasploit)	linux/remote/25775.rb
Nginx 1.3.9 < 1.4.0 - Denial of Service (PoC)	linux/dos/25499.py
Nginx 1.3.9/1.4.0 (x86) - Brute Force	linux_x86/remote/26737.pl
Nginx 1.4.0 (Generic Linux x64) - Remote Overflow	linux_x86-64/remote/32277.txt
PHP-FPM + Nginx - Remote Code Execution	php/webapps/47553.md

```
Shellcodes: No Results
```



การสอดแนมแบบ : Reconnaissance

■ Fingerprint – Exploit Mapping

[Home](#)[Exploits](#)[Shellcode](#)[Papers](#)[Google Hacking Database](#)[Submit](#)[Search](#)

Search the Exploit Database

Search the Database for Exploits, Papers, and Shellcode. You can even search by **CVE** and **OSVDB** identifiers.



I'm not a robot



reCAPTCHA
Privacy - Terms

SEARCH

More Options

1 total entries

Date ▼	D	A	V	Title	Platform	Author
2011-07-05	↓	⚠	✓	vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)	Unix	Metasploit



การสอดแนมแบบ : Reconnaissance

■ Fingerprint – Exploit Mapping

EXPLOIT DATABASE

Home

Exploits

Shellcode

Papers

Google Hacking Database

Submit

Search

```
17 include Msf::Exploit::Remote::Tcp
18
19 def initialize(info = {})
20   super(update_info(info,
21     'Name' => 'VSFTPD v2.3.4 Backdoor Command Execution',
22     'Description' => %q{
23       This module exploits a malicious backdoor that was added to the VSFTPD download
24       archive. This backdoor was introduced into the vsftpd-2.3.4.tar.gz archive between
25       June 30th 2011 and July 1st 2011 according to the most recent information
26       available. This backdoor was removed on July 3rd 2011.
27     },
28     'Author' => [ 'hdm', 'mc' ],
29     'License' => MSF_LICENSE,
30     'Version' => '$Revision: 13099 $',
31     'References' =>
32       [
33         [ 'URL', 'http://pastebin.com/AetT9sS5'],
34         [ 'URL', 'http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html' ],
35       ],
36     'Privileged' => true,
37     'Platform' => [ 'unix' ],
38     'Arch' => ARCH_CMD,
39     'Payload' =>
```




การสอดแนมแบบ : Reconnaissance

- Fingerprint – Exploit Mapping



กิจกรรมที่ 10
ทดสอบการ Scan และ Enum

Metasploitable 2





ลงทะเบียนอบรม



วันที่ 4 พฤศจิกายน 2568 รอบบ่าย



การสอดแนมแบบ : Reconnaissance

■ Web Path Enumeration

dirb <http://testphp.vulnweb.com/> /usr/share/wordlists/dirb/small.txt

```
(kali@ kali)-[~]
$ dirb

-----
DIRB v2.22
By The Dark Raver
-----

dirb <url_base> [<wordlist_file(s)>] [options]

===== NOTES =====
<url_base> : Base URL to scan. (Use -resume for session resuming)
<wordlist_file(s)> : List of wordfiles. (wordfile1,wordfile2,wordfile3...)

===== HOTKEYS =====
'n' -> Go to next directory.
'q' -> Stop scan. (Saving state for resume)
'r' -> Remaining scan stats.

===== OPTIONS =====
-a <agent_string> : Specify your custom USER_AGENT.
-b : Use path as is.
-c <cookie_string> : Set a cookie for the HTTP request.
-E <certificate> : path to the client certificate.
-f : Fine tuning of NOT_FOUND (404) detection.
-H <header_string> : Add a custom header to the HTTP request.
-i : Use case-insensitive search.
-l : Print "Location" header when found.
-N <nf_code>: Ignore responses with this HTTP code.
-o <output_file> : Save output to disk.
-p <proxy[:port]> : Use this proxy. (Default port is 1080)
-P <proxy_username:proxy_password> : Proxy Authentication.
-r : Don't search recursively.
-R : Interactive recursion. (Asks for each directory)
-S : Silent Mode. Don't show tested words. (For dumb terminals)
-t : Don't force an ending '/' on URLs.
-u <username:password> : HTTP Authentication.
-v : Show also NOT_FOUND pages.
```



การสอดแนมแบบ : Reconnaissance

■ Web Path Enumeration

dirb <http://testphp.vulnweb.com/> /usr/share/wordlists/dirb/small.txt

```
(kali@ kali)-[~]
$ dirb http://testphp.vulnweb.com/ /usr/share/wordlists/dirb/small.txt

-----
DIRB v2.22
By The Dark Raven
-----

START_TIME: Sun Nov  2 04:11:55 2025
URL_BASE: http://testphp.vulnweb.com/
WORDLIST_FILES: /usr/share/wordlists/dirb/small.txt

-----

GENERATED WORDS: 959

---- Scanning URL: http://testphp.vulnweb.com/ ----
==> DIRECTORY: http://testphp.vulnweb.com/CVS/
==> DIRECTORY: http://testphp.vulnweb.com/admin/
dirb http://testphp.vulnweb.com/ /usr/share/wordlists/dirb/small.txt
+ Remaining scan stats:
Words: 886 | Directories: 2
+ Going to next directory.

---- Entering directory: http://testphp.vulnweb.com/CVS/ ----
+ Remaining scan stats:
Words: 946 | Directories: 1
+ Remaining scan stats:
Words: 941 | Directories: 1
+ Remaining scan stats:
Words: 936 | Directories: 1
+ Remaining scan stats:
Words: 926 | Directories: 1

---- Entering directory: http://testphp.vulnweb.com/admin/ ----
```




การสอดแนมแบบ : Reconnaissance

■ Web Path Enumeration - DirBuster

OWASP DirBuster 1.0-RC1 - Web Application Brute Forcing

File Options About Help

Target URL (eg http://example.com:80/)
http://testphp.vulnweb.com/

Work Method ☐ Use GET requests only ☒ Auto Switch (HEAD and GET)

Number Of Threads 10 Threads ☐ Go Faster

Select scanning type: ☒ List based brute force ☐ Pure Brute Force

File with list of dirs/files
/usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-medium.txt

Char set Min length Max Length

Select starting options: ☒ Standard start point ☐ URL Fuzz

☒ Brute Force Dirs ☒ Be Recursive Dir to start with

☒ Brute Force Files ☐ Use Blank Extension File extension

URL to fuzz - /test.html?url={dir}.asp

Please complete the test details



การสอดแนมแบบ : Reconnaissance

■ Web Path Enumeration

OWASP DirBuster 1.0-RC1 - Web Application Brute Forcing

File Options About Help

http://testphp.vulnweb.com:80/

Scan Information Results - List View: Dirs: 7 Files: 14 Results - Tree View Errors: 0

Directory Structure	Response Code	Response Size
/	200	5293
index.php	200	228
search.php	200	228
login.php	200	228
images	200	155
cgi-bin	403	460
categories.php	200	228
artists.php	200	228
disclaimer.php	200	228
cart.php	200	228
guestbook.php	200	228
AJAX	200	228

Current speed: 38 requests/sec (Select and right click for more options)

Average speed: (T) 35, (C) 35 requests/sec

Parse Queue Size: 0

Total Requests: 1096/3322113

Current number of running threads: 10

Time To Finish: 1 Day

Back Pause Stop

Report

Starting dir/file list based brute forcing

/hpp/events.php



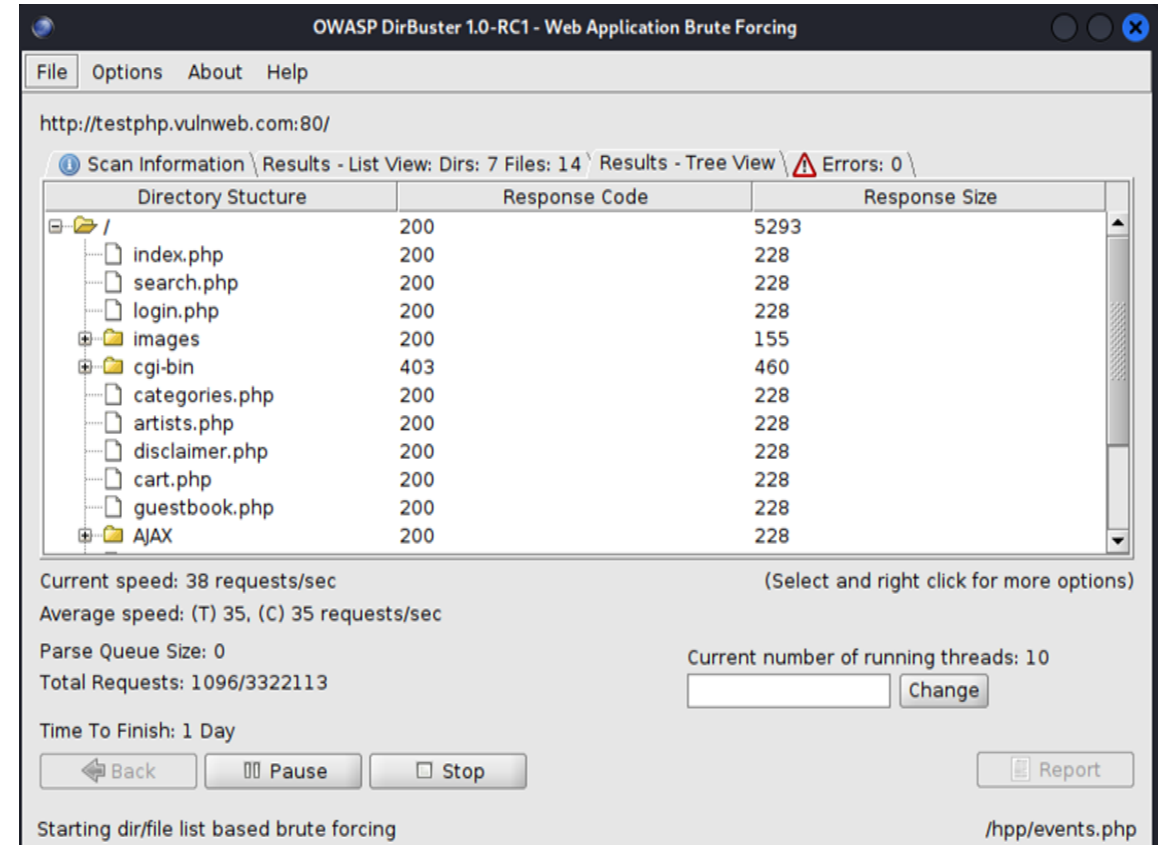
การสอดแนมแบบ : Reconnaissance

■ Fingerprint – Exploit Mapping



กิจกรรมที่ 10-1 ทดสอบการ Web Path Enum

- <https://play.mooc.ncsa.or.th/lab/47>
- <http://testphp.vulnweb.com/>

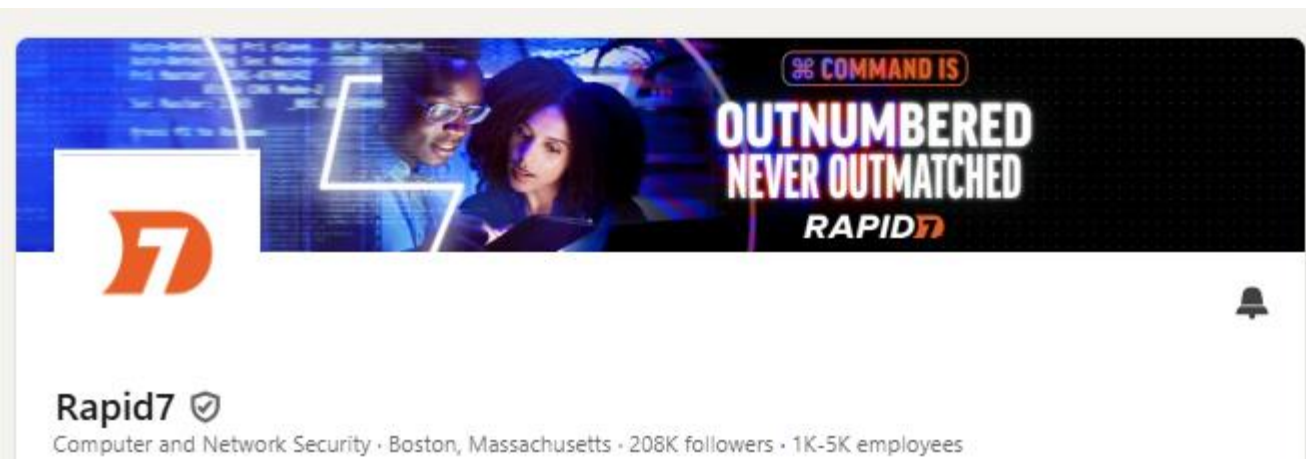




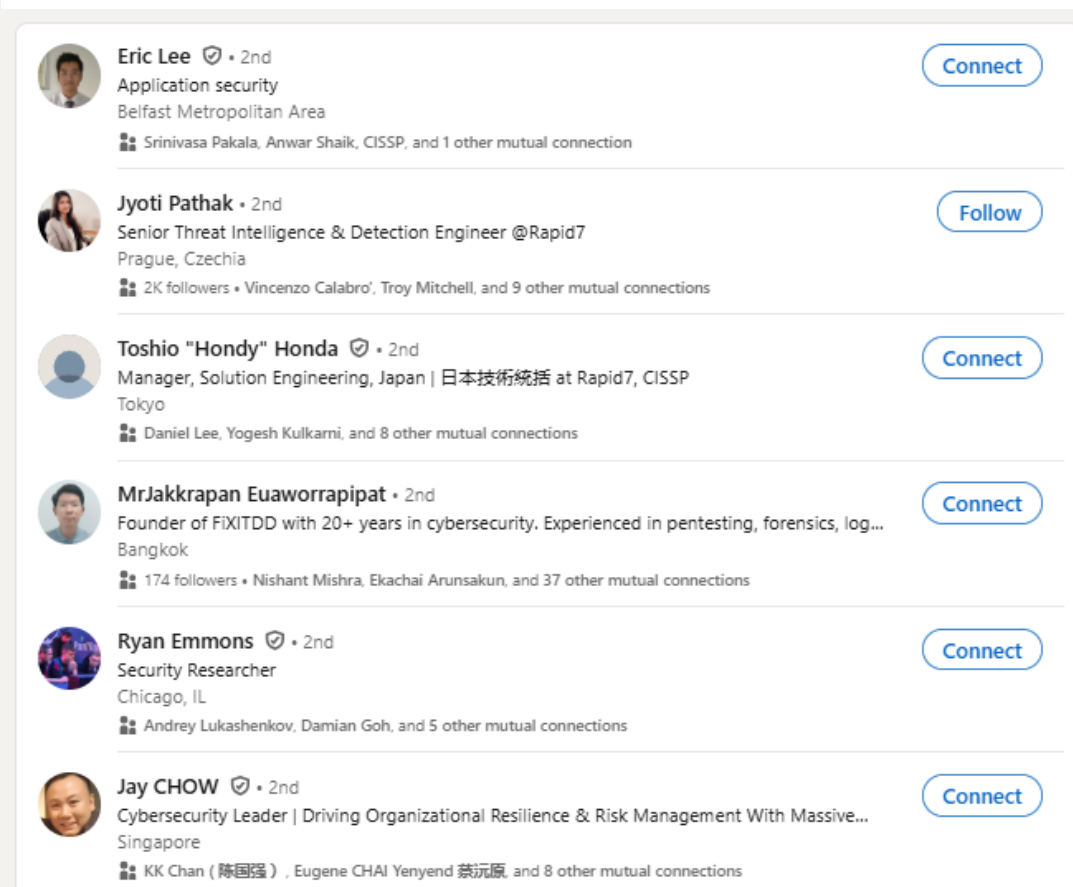
การสอดแนมแบบ : Reconnaissance



■ User Enumeration : Linked In



- [firstname][lastname]@[company].com
- [firstname].[lastname]@[company].com
- [firstinitial][lastname]@[company].com
- [firstname]@[company].com





การสอดแนมแบบ : Reconnaissance

■ User Enumeration : Email Finder

Prospero Products ▼ Resources ▼ Pricing

rapid7.com **Find emails**

All ▼ 1196 emails found

ar@rapid7.com	Professional	Verify
Ryan Alverson		
jbednar@rapid7.com	Professional	Verify
Jordan Bednar		
chrome_plugin@rapid7.com	Professional	Verify
Chrome Plugin		
platformsupport@rapid7.com	Generic	Verify



การสอดแนมแบบ : Reconnaissance

■ User Enumeration – Web

Login

Username: rapid7

That user does not exist.

Password:

Submit

Username: admin

Password:

The password is incorrect.

Submit

Reset Password

Password Reset

Username: rapid7

Submit

That username does not exist.

Register

Username: admin

Submit

That username already exist



การสอดแนมแบบ : Reconnaissance

■ User Enumeration – Web with burp suite

Payload Options [Simple list]

This payload type lets you configure a simple list of strings that are

Paste

Load ...

Remove

Clear

Add

root

admin

test

guest

info

adm

mysql

Enter a new item

Target Positions Payloads Options

? **Payload Positions**

Configure the positions where payloads will be inserted into the base request. The attack type determines the way in which payloads are assigned to payload positions - see help for full details.

Attack type: Sniper

POST /log

Host: ac6

User-Agent: Firefox/8

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8

Accept-Language: en-US,en;q=0.5

Accept-Encoding: gzip, deflate

Content-Type: application/x-www-form-urlencoded

Content-Length: 27

Cookie: session=OFJBGdsJAaU2XO7iLAixAqUmaQRPiFTT

Upgrade-Insecure-Requests: 1

username=\$test\$&password=\$test\$



การสอดแนมแบบ : Reconnaissance

- Fingerprint – Exploit Mapping



กิจกรรมที่ 11 User Enumeration





การสอดแนมแบบ : Reconnaissance

■ Credential Leaked – Intel X

_IntelligenceX



vulnweb.com

Search

Advanced

Found 1000+ Text Files, 1000+ Website HTMLs, 867 Pastes, 300 Database Files, 226 CSV Files, 27 PDF Files, 16 HTML Files, 5 Word Files, 1 Domain, 1 Excel File, 1 Ebook File

2020-11-03 13:48:16

www.vulnweb.com - Acunetix Web Vulnerability Scanner - Test websites

2020-11-08 - 2020-12-10

34m.txt [Part 222 of 269]

2023-09-26 15:06:05

nikitastogul@mail. [redacted] kita198
aliko@live.co.uk [redacted] zoryarraki1
mail@ya.ru:123456 [redacted]
sample@email.tst: [redacted] d6
password@gmail.co [redacted] ktar
andynls23@yahoo.co [redacted] 82101367
lbthach88@gmail.co [redacted] 011988
adambward@gmail.co [redacted] ronical91123

Full Data

10 000 000 CORP (3).txt [Part 64 of 80]

2022-12-08 10:27:30

kanal@myself.com [redacted] cing

← Back to results



34m.txt [Part 222 of 269]

2023-09-26 15:06:05

Document

Tree View

Metadata

Selectors

Actions

Search:

nikitastogul@mail. [redacted] 198
aliko@live.co.uk: [redacted] raki1
mail@ya.ru:123456 [redacted]
sample@email.tst:f [redacted]
password@gmail.co [redacted]
andynls23@yahoo.co [redacted] 367
lbthach88@gmail.co [redacted] 8
adambward@gmail.co [redacted] al91123
manuelgardina@gmai [redacted] uelG
unadkat1981@hotmail [redacted]
none@none.com:cmm [redacted]
asd@asd.com:smudge [redacted]
cnlow14@hotmail.co [redacted]
petrmissial@gmail. [redacted] 181
yanyu.shih@msa.hin [redacted] gelblue
elcio081@hotmail.co [redacted] www
litecoinwilde@gmai [redacted] ecoinwilde
extro24@gmail.com: [redacted]
mail@mail.ru:voveg [redacted]
hamstersalad.1990@ [redacted] :eckert1
adamhawkin@hotmail [redacted] srlfc1
lukevelleman@yahoo [redacted] llout!
shaondc@gmail.com: [redacted]
charlie47@mailtor. [redacted] ie55



การสอดแนมแบบ : Reconnaissance

■ Credential Leaked - StealthMole

The screenshot displays the StealthMole web interface. The top navigation bar includes the StealthMole logo, a search bar with the text "netskope.com", and a user profile icon. On the left, a sidebar contains various tool icons (DT, TT, CDS, CS, CL, UB, RM, LM, GM, DA, DM, IOL, +). The main content area shows a table of 414 results for "netskope.com". The table has columns for Host, User, Password, and Leaked Date (UTC+0). The first row is highlighted, showing a credential for "cnanduri@netskope.com" with password "@Dianvi182604" leaked on 2025-05-10. To the right of the table, there is a network diagram showing connections between various hosts and users, including "https://secure.newportgroup.com/", "@Dianvi182604", "cnanduri@netskope.com", and "netskope.com". The bottom status bar indicates "Caribou - 2025-05-26 06:33:56".

Host	User	Password	Leaked Date (UTC+0)
https://secure.newportgroup.com/	cnanduri@netskope.com	@Dianvi182604	2025-05-10 13:04:08
https://support.netskope.com/s/login/	sudar.thankaswamy@navitaslifesciences.com	Strangerthings@123	2025-05-09 19:09:56
https://support.netskope.com	adam.powers@hpe.com	every60days!again	2025-05-05 15:49:12
https://support.netskope.com	o20482@365up.club	Diomedes2020	2025-05-05 15:49:12
https://auth.dpass.us.deloitte.com	dnicholas@netskope.com	RZYxU7t?bR46i#y	2025-05-01 12:19:35
https://dayblink.goskope.com	dnicholas@netskope.com	Dfispel1	2025-05-01 12:19:35
https://motrex.goskope.com	dnicholas@netskope.com	Dfispel1	2025-05-01 12:19:35
https://signin.ea.com	skhatri@netskope.com	Password@123@	2025-05-01 12:19:35
https://sso.netskope.io	dnicholas@netskope.com	Dfispel1ne	2025-05-01 12:19:35
https://cloudfksecurity.eu.goskope.com	skhatri@netskope.com	P@ssw0rd@123@	2025-04-26 14:32:07
https://colpipe.goskope.com	dnicholas@netskope.com	Dfispel1	2025-04-26 14:32:07
https://netskope.zendesk.co	dnicholas@netskope.com	Dfispel1	2025-04-26 14:32:07



การสอดแนมแบบ : Reconnaissance

- Fingerprint – Exploit Mapping



กิจกรรมที่ 12 Credential Leaked Searching





การสอดแนมแบบ : Reconnaissance

■ Source Code Leaked in Public Repo



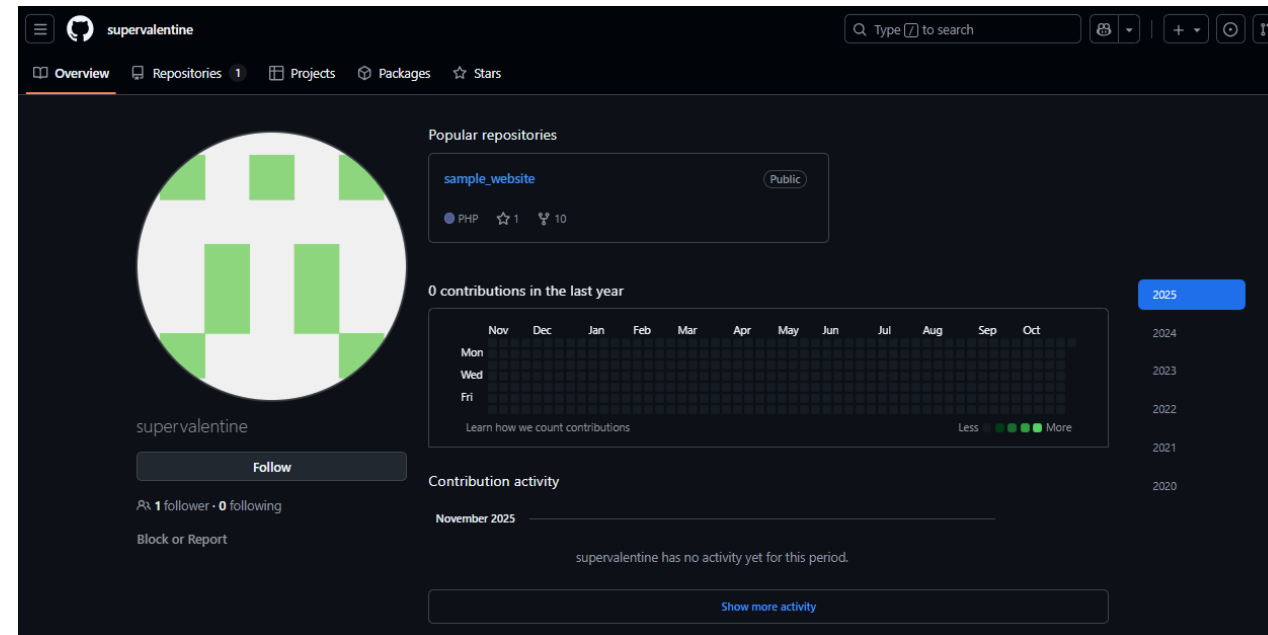
Cover

[Home](#) [Features](#) [Contact](#)

Hello World

This is a simple one page website, please feel free to comment me on github.

By @supervalentine



```
35 <main role="main" class="inner cover">
36 <h1 class="cover-heading">Hello World</h1>
37 <p class="lead">This is a simple one page website, please feel free to comment me on github.</p>
38 <p class="lead">
39 <a href="#" class="btn btn-lg btn-secondary">By @supervalentine</a>
40 <?php
41 $user=$_GET["username"];
42 $credential=$_GET["credential"];
43 if($user=="sa"&&$credential=="JDM82XDVMcNI~wpdw7ZQ5")
44 {
45     echo "<br><br>The flag is ";
46 }
47 ?>
48 </p>
49 </main>
50
```




การสอดแนมแบบ : Reconnaissance

■ Source Code Leaked in Public Repo

ตัวอย่างการหาข้อมูล	ผลลัพธ์
"victim.com" password	ค้นหา source code ที่มีคำว่า "victim.com" และมีคำว่า password
"victim.com" ftp	ค้นหา source code ที่มีคำว่า "victim.com" และมีคำว่า ftp
"victim.com" ssh	ค้นหา source code ที่มีคำว่า "victim.com" และมีคำว่า ssh
"victim.com" secret	ค้นหา source code ที่มีคำว่า "victim.com" และมีคำว่า secret
"victim.com" credential	ค้นหา source code ที่มีคำว่า "victim.com" และมีคำว่า credential
"victim.com" key	ค้นหา source code ที่มีคำว่า "victim.com" และมีคำว่า key
"victim.com" token	ค้นหา source code ที่มีคำว่า "victim.com" และมีคำว่า token
"victim.com" config	ค้นหา source code ที่มีคำว่า "victim.com" และมีคำว่า config
"victim.com" login	ค้นหา source code ที่มีคำว่า "victim.com" และมีคำว่า login
"victim.com" pwd	ค้นหา source code ที่มีคำว่า "victim.com" และมีคำว่า pwd
"victim.com" send_keys	ค้นหา source code ที่มีคำว่า "victim.com" และมีคำว่า send_keys
"victim.com" connectionstring	ค้นหา database connection ขององค์กร victim.com
"victim.com" JDBC	ค้นหา database connection ขององค์กร victim.com
"victim.com" ssh2_auth_password	ค้นหา ssh connection ขององค์กร victim.com
"victim.com" key	ค้นหา source code ที่มีคำว่า "victim.com" และมีคำว่า key
"victim.com" security_credentials	ค้นหา LDAP connection ขององค์กร victim.com
"victim.com" filename:sftp-config.json	ค้นหาไฟล์ sftp-config.json ของไฟล์ที่มีคำว่า "victim.com" อยู่ด้วย
filename:.env MAIL_HOST=smtp.gmail.com	ค้นหาไฟล์ configure .env โดยมีค่า MAIL_HOST=smtp.gmail.com อยู่ด้วย
extension:sql mysql dump	ค้นหาไฟล์ที่มีนามสกุล sql และมีคำว่า mysql dump อยู่



การสอดแนมแบบ : Reconnaissance

■ Fingerprint – Exploit Mapping

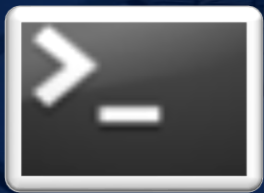


กิจกรรมที่ 12

Source Code Leaked in Public Repo

- <https://play.mooc.ncsa.or.th/lab/38>
- Your Domains





การสำรวจออกแบบรายงานสรุป Recon



การสอดแนมแบบ : Reconnaissance

Attack Surface



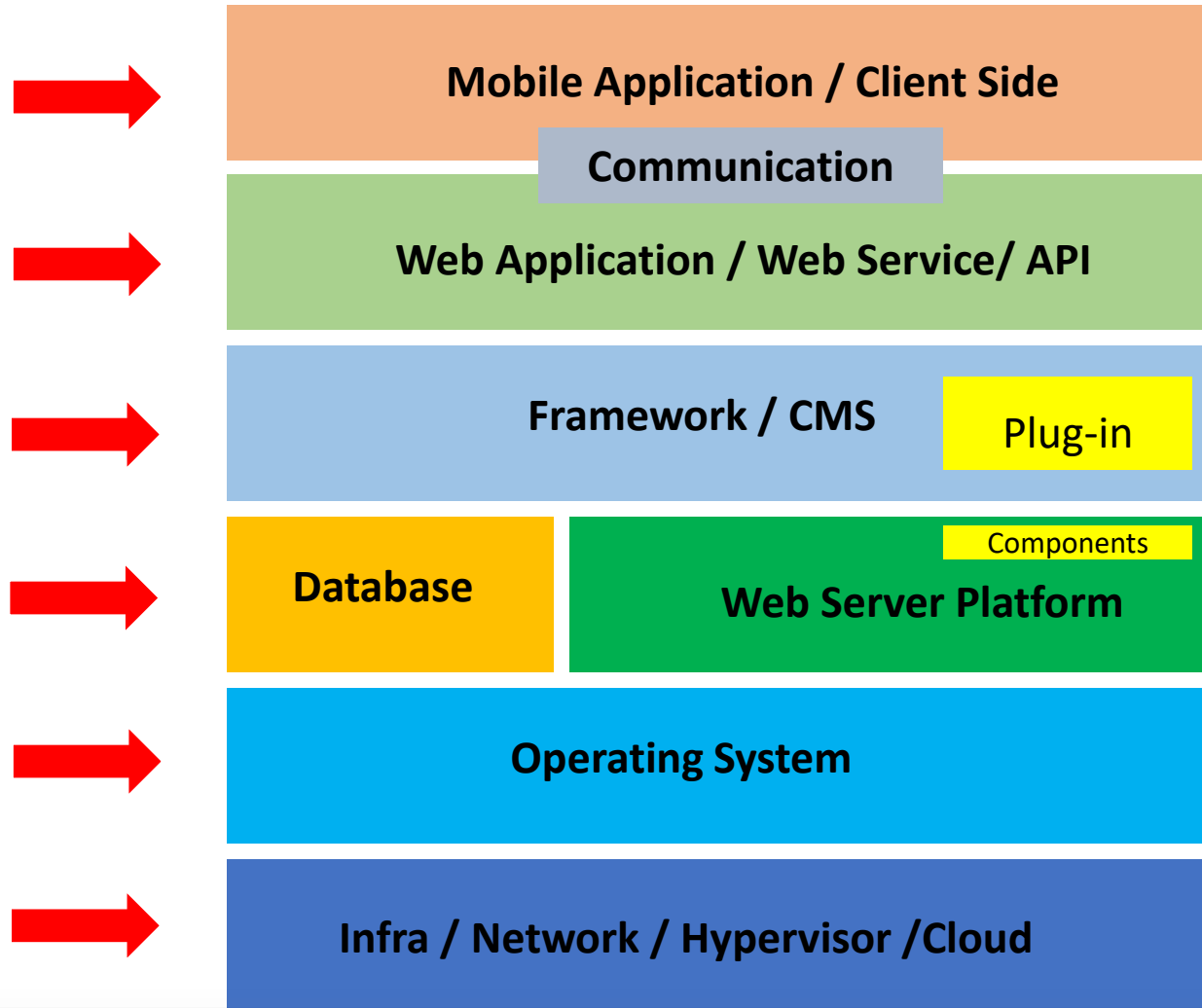


การสอดแนมแบบ : Reconnaissance

Attack Surface



Threat Actor





การสอดแนมแบบ : Reconnaissance



Information gathered during reconnaissance

- **Technical Information:**
 - IP addresses, domain names, and network topology
 - Open ports and services running on those ports
 - Operating systems, applications, and software versions
 - Leaked Data
- **Organizational and Human Information:**
 - Employee names and email addresses
 - Information about the company's structure, partners, and business partners
 - Details gathered from public sources like company websites and social media



การสอดแนมแบบ : Reconnaissance



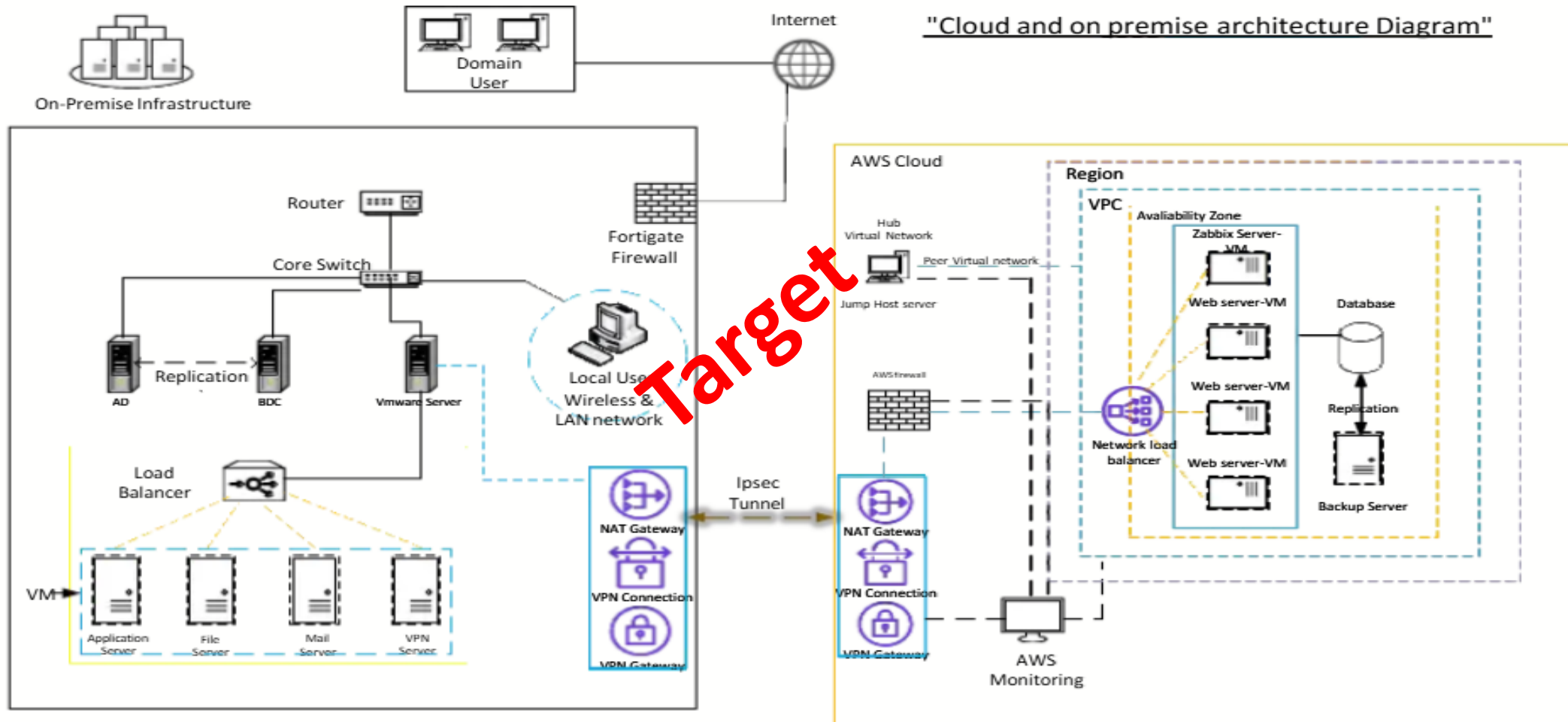
Repos



Employees



Leak Data and Credentials

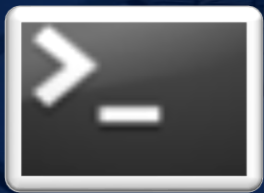


A hooded figure, possibly a hacker, is visible in the background, partially obscured by the text. The figure is wearing a dark hood and a dark jacket. The background is dark blue with vertical columns of green binary code (0s and 1s) falling like rain, reminiscent of the 'Matrix' effect. The figure's face is not visible, and they appear to be looking down or at something out of frame.

OFFSEC SAYS

YOU MUST

TRY HARDER



สรุปการอบรมวันที่ 2



สรุปการอบรมวันที่ 2 การทดสอบเจาะระบบพื้นฐาน

- ✓ Passive Reconnaissance
- ✓ Active Reconnaissance
- ✓ การทำแผนที่เครือข่ายและการระบุ fingerprint ของบริการ
- ✓ การสำรวจออกแบบรายงานสรุป Recon





ถาม/ตอบ



NCSA OSCP Bootcamp

Invite friends you want to share this OpenChat with.



Email: ammarit.t@secure-d.tech

การทดสอบเจาะระบบพื้นฐาน (Basic Penetration Testing)

โครงการพัฒนาบุคลากรด้านการตรวจสอบความมั่นคงปลอดภัยไซเบอร์และทดสอบเจาะระบบระดับสูง

(Offensive Security Certified Professional: OSCP Bootcamp)

